Módulo 4: Seguridad en la nube de AWS

AWS Academy Cloud Foundations

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Información general sobre el módulo

Temas

- Modelo de responsabilidad compartida de AWS
- AWS Identity and Access Management (IAM)
- Protección de una cuenta nueva de AWS
- Protección de cuentas
- Protección de datos en AWS
- Trabajo para garantizar la conformidad

Actividades

- Actividad sobre el modelo de responsabilidad compartida de AWS

Demostración

- Demostración grabada de IAM

Laboratorio

- Introducción a AWS IAM



Revisión de conocimientos

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Objetivos del módulo

Después de completar este módulo, debería ser capaz de lo siguiente:

- Reconocer el modelo de responsabilidad compartida
- Identificar la responsabilidad del cliente y de AWS
- Reconocer usuarios, grupos y roles de IAM
- Describir los diferentes tipos de credenciales de seguridad en IAM
- Identificar los pasos para proteger una nueva cuenta de AWS
- Explorar los usuarios y los grupos de IAM
- Reconocer cómo proteger los datos de AWS
- Reconocer los programas de conformidad de AWS

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Sección 1: Modelo de responsabilidad compartida de AWS

Módulo 4: Seguridad en la nube de AWS



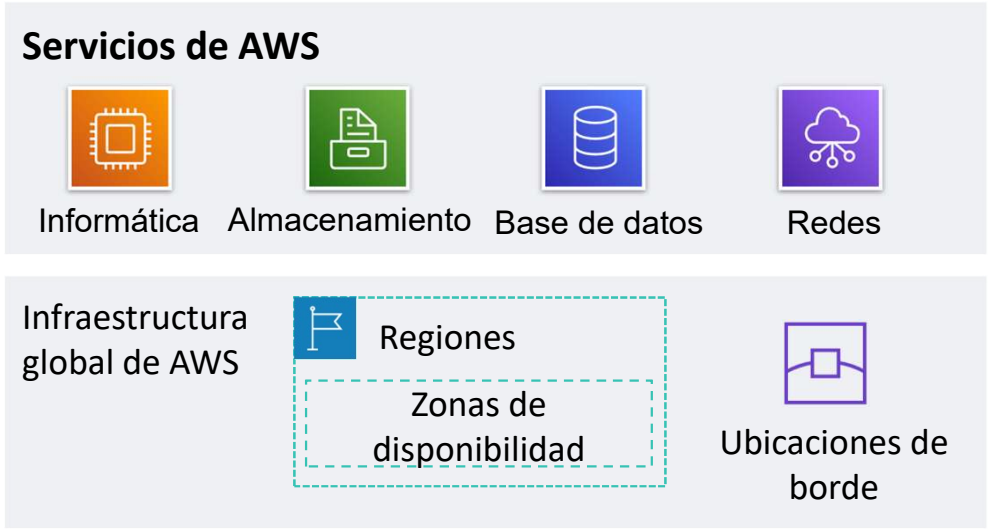
© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Modelo de responsabilidad compartida de AWS



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Responsabilidad de AWS: seguridad *de* la nube



Responsabilidades de AWS:



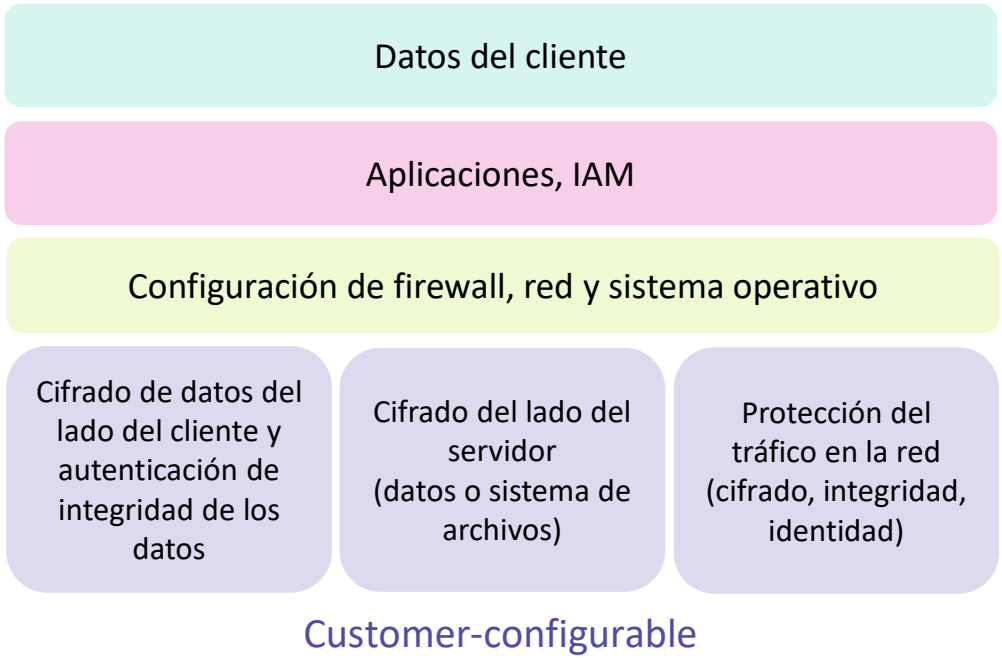
- Seguridad física de los centros de datos
  - Acceso controlado basado en las necesidades
- Infraestructura de hardware y software
  - Baja de recursos de almacenamiento, registro de acceso del sistema operativo (SO) del host y auditoría
- Infraestructura de red
  - Detección de intrusiones



- Infraestructura de virtualización
  - Aislamiento de instancias

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Responsabilidad del cliente: seguridad en la nube



Responsabilidades de los clientes:

- Sistema operativo de la instancia de Amazon Elastic Compute Cloud (Amazon EC2)
  - Incluidos los parches y el mantenimiento
- Aplicaciones
  - Contraseñas, acceso basado en roles, etc.
- Configuración del grupo de seguridad
- SO o firewalls basados en host
  - Incluidos los sistemas de detección o prevención de intrusiones
- Configuraciones de red
- Administración de cuentas
  - Configuración de inicio de sesión y permisos para cada usuario

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Características del servicio y responsabilidad en materia de seguridad

Servicios de ejemplo administrados por el cliente



Amazon EC2



Amazon Elastic Block Store (Amazon EBS)



Amazon Virtual Private Cloud (Amazon VPC)

Servicios de ejemplo administrados por AWS



AWS Lambda



Amazon Relational Database Service (Amazon RDS)



AWS Elastic Beanstalk

Infraestructura como servicio (IaaS)

- El cliente tiene más flexibilidad en lo que respecta a la configuración de redes y almacenamiento.
- El cliente es responsable de administrar más aspectos de la seguridad.
- El cliente configura los controles de acceso.

Plataforma como servicio (PaaS)

- El cliente no necesita administrar la infraestructura subyacente.
- AWS gestiona el sistema operativo, la implementación de parches a la base de datos, la configuración del firewall y la recuperación de desastres.
- El cliente puede centrarse en la administración de código o datos.

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Características del servicio y responsabilidad en materia de seguridad (continuación)

Ejemplos de SaaS



AWS Trusted Advisor



AWS Shield



Amazon Chime

Software como servicio (SaaS)

- El software está alojado de forma centralizada.
- Cuenta con licencia según un modelo de suscripción o de pago por uso.
- Normalmente, el acceso a los servicios se realiza a través de un navegador web, una aplicación móvil o una interfaz de programación de aplicaciones (API).
- Los clientes no necesitan administrar la infraestructura que respalda el servicio.

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Actividad: Modelo de responsabilidad compartida de AWS

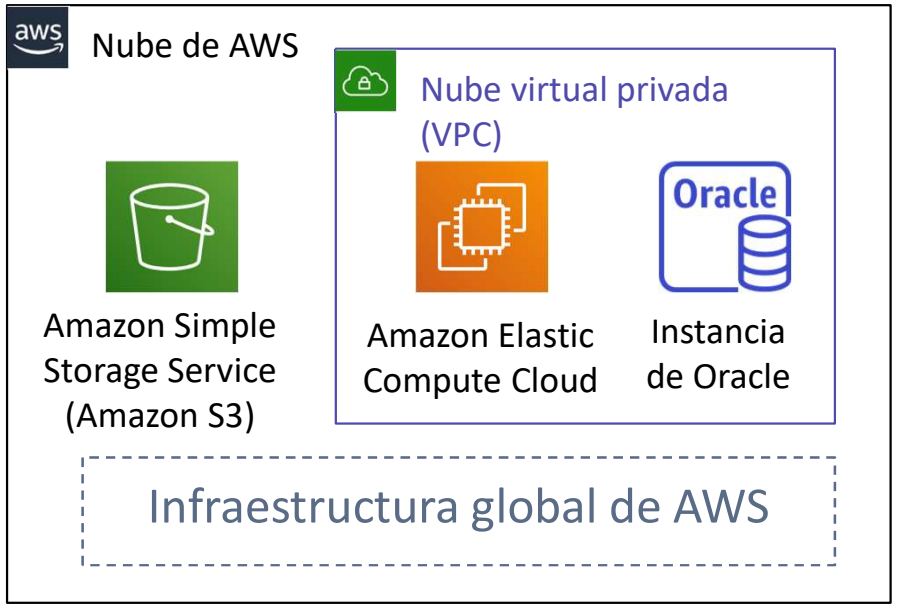


Photo by Pixabay from Pexels.

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Actividad: Escenario 1 de 2

Considere esta implementación. ¿Quién es responsable: AWS o el cliente?

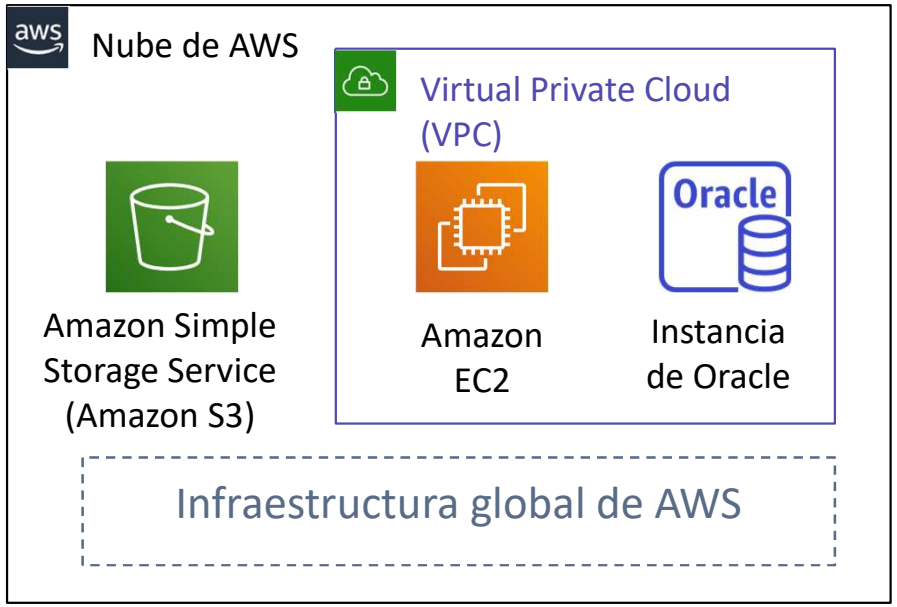


1. ¿Actualizaciones y parches del sistema operativo en la instancia de EC2?
2. ¿Seguridad física de los centros de datos?
3. ¿Infraestructura de virtualización?
4. ¿Configuración del grupo de seguridad EC2?
5. ¿Configuración de aplicaciones que se ejecutan en la instancia de EC2?
6. ¿Actualizaciones o parches de Oracle si la instancia de Oracle se ejecuta como una instancia de Amazon RDS?
7. ¿Actualizaciones o parches de Oracle si Oracle se ejecuta en una instancia de EC2?
8. ¿Configuración de acceso al bucket de S3?

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Actividad: escenario 1 de 2

Considere esta implementación. ¿Quién es responsable? ¿AWS o el cliente?

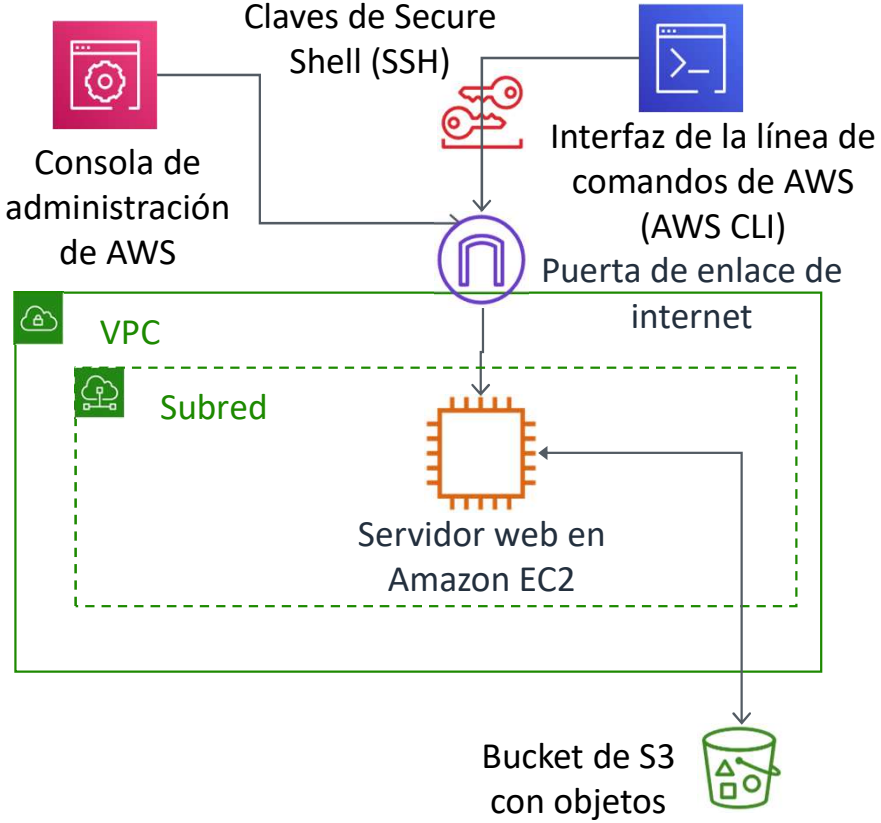


1. ¿Actualizaciones y parches en el sistema operativo en la instancia EC2?
   - **RESPUESTA:** el cliente
2. ¿Seguridad física del centro de datos?
   - **RESPUESTA:** AWS
3. ¿Infraestructura de virtualización?
   - **RESPUESTA:** AWS
4. ¿Configuración de grupos de seguridad de EC2?
   - **RESPUESTA:** el cliente
5. ¿Configuración de las aplicaciones que se ejecutan en la instancia EC2?
   - **RESPUESTA:** el cliente
6. ¿Actualizaciones o parches de Oracle si la instancia de Oracle se ejecuta como una instancia de Amazon RDS?
   - **RESPUESTA:** AWS
7. ¿Actualizaciones o parches de Oracle si Oracle se ejecuta en una instancia EC2?
   - **RESPUESTA:** el cliente
8. ¿Configuración de acceso al bucket de S3?
   - **RESPUESTA:** el cliente

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Actividad: Escenario 2 de 2

Considere esta implementación. ¿Quién es responsable: AWS o el cliente?

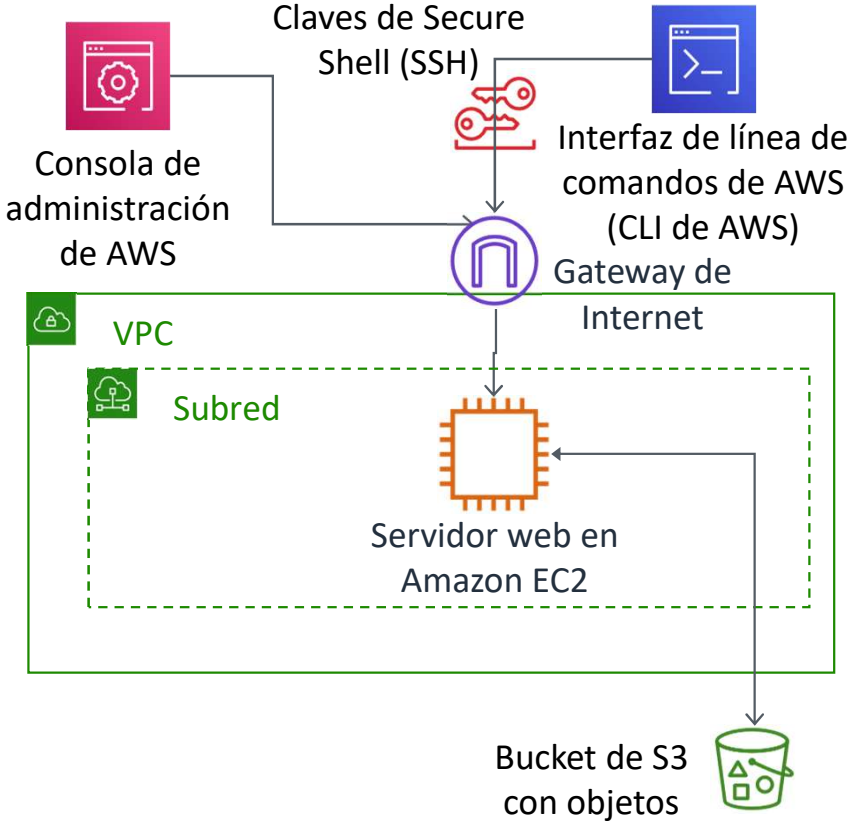


1. ¿Se asegura de que la Consola de administración de AWS no sea pirateada?
2. ¿Configurando la subred?
3. ¿Configurando la VPC?
4. ¿Protección contra las interrupciones de la red en las regiones de AWS?
5. Proteger las claves SSH
6. ¿Garantizar el aislamiento de la red entre los datos de los clientes de AWS?
7. ¿Garantizar una conexión de red de baja latencia entre el servidor web y el bucket de S3?
8. ¿Hacer cumplir la autenticación multifactor para todos los inicios de sesión de los usuarios?

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Actividad: escenario 2 de 2

Considere esta implementación. ¿Quién es responsable? ¿AWS o el cliente?



1. ¿Garantizar que la consola de administración de AWS no sea pirateada?
   - **RESPUESTA:** AWS
2. ¿Configurar la subred?
   - **RESPUESTA:** el cliente
3. ¿Configurar la VPC?
   - **RESPUESTA:** el cliente
4. ¿Proteger frente a interrupciones de red en las regiones de AWS?
   - **RESPUESTA:** AWS
5. ¿Proteger las claves SSH?
   - **RESPUESTA:** el cliente
6. ¿Garantizar el aislamiento de red entre los datos de los clientes de AWS?
   - **RESPUESTA:** AWS
7. ¿Garantizar una conexión de red de baja latencia entre el servidor web y el bucket de S3?
   - **RESPUESTA:** AWS
8. ¿Requerir la autenticación multifactor para todos los inicios de sesión de los usuarios?
   - **RESPUESTA:** el cliente

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Aprendizajes clave de la sección 1



- AWS y el cliente comparten responsabilidades en materia de seguridad:
  - AWS es responsable de la seguridad de la nube.
  - El cliente es responsable de la seguridad en la nube.
- **AWS es responsable de proteger la infraestructura** (incluido el hardware, el software, las redes y las instalaciones) que ejecuta los servicios en la nube de AWS.
- En el caso de los servicios clasificados como infraestructura como servicio (IaaS), el **cliente es responsable de realizar las tareas de configuración y administración de seguridad necesarias.**
  - Por ejemplo, actualizaciones del sistema operativo invitado y configuraciones de parches de seguridad, firewall y grupos de seguridad.

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Sección 2: AWS Identity and Access Management (IAM)

Módulo 4: Seguridad en la nube de AWS



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

AWS Identity and Access Management (IAM)

- Utilice **IAM** para administrar el acceso a los **recursos de AWS**:
  - Un recurso es una entidad en una cuenta de AWS con la que puede trabajar.
  - Recursos de ejemplo: una instancia de Amazon EC2 o un bucket de Amazon S3

- *Por ejemplo:* controle quién puede terminar instancias de Amazon EC2

- Defina los derechos de acceso detallados:
  - **Quién** puede obtener acceso al recurso
  - **A qué** recursos se puede obtener acceso y qué puede hacer el usuario con el recurso
  - **Cómo** se puede obtener acceso a los recursos

- IAM es una característica de cuenta de AWS gratuita



AWS Identity and Access Management (IAM)

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

IAM: componentes esenciales



Usuario de IAM

Persona *o* **aplicación** que se puede autenticar con una cuenta de AWS



Grupo de IAM

Colección de usuarios de IAM a los que se concede una autorización idéntica



Política de IAM

El documento que define **a qué recursos se puede obtener acceso** y el **nivel de acceso** a cada recurso



Rol de IAM

Mecanismo útil para conceder un conjunto de permisos a fin de realizar solicitudes de servicios de AWS

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Autenticarse como usuario de IAM para obtener acceso

Cuando define un **usuario de IAM**, selecciona qué ***tipos de acceso*** puede utilizar el usuario.

• Acceso *mediante programación*

- Se autentica con lo siguiente:
  - ID de clave de acceso
  - Clave de acceso secreta
- Proporciona acceso a la CLI de AWS y al SDK de AWS.



CLI de AWS



Herramientas y SDK de AWS

Acceso a la consola de administración de AWS

- Se autentica con lo siguiente:
  - ID de cuenta *o* alias de 12 dígitos
  - Nombre de usuario de IAM
  - Contraseña de IAM
- Si está habilitada, **Multi-Factor Authentication (MFA)** solicita un código de autenticación.



Consola de administración de AWS

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

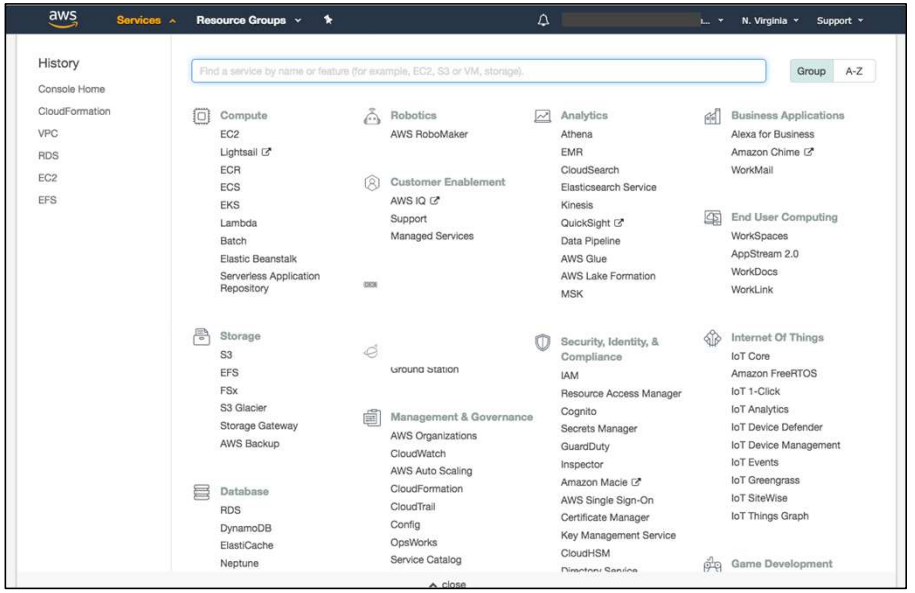
MFA de IAM

- MFA proporciona más seguridad.

- Además del **nombre de usuario** y la **contraseña**, MFA requiere un código de autenticación único para acceder a los servicios de AWS.





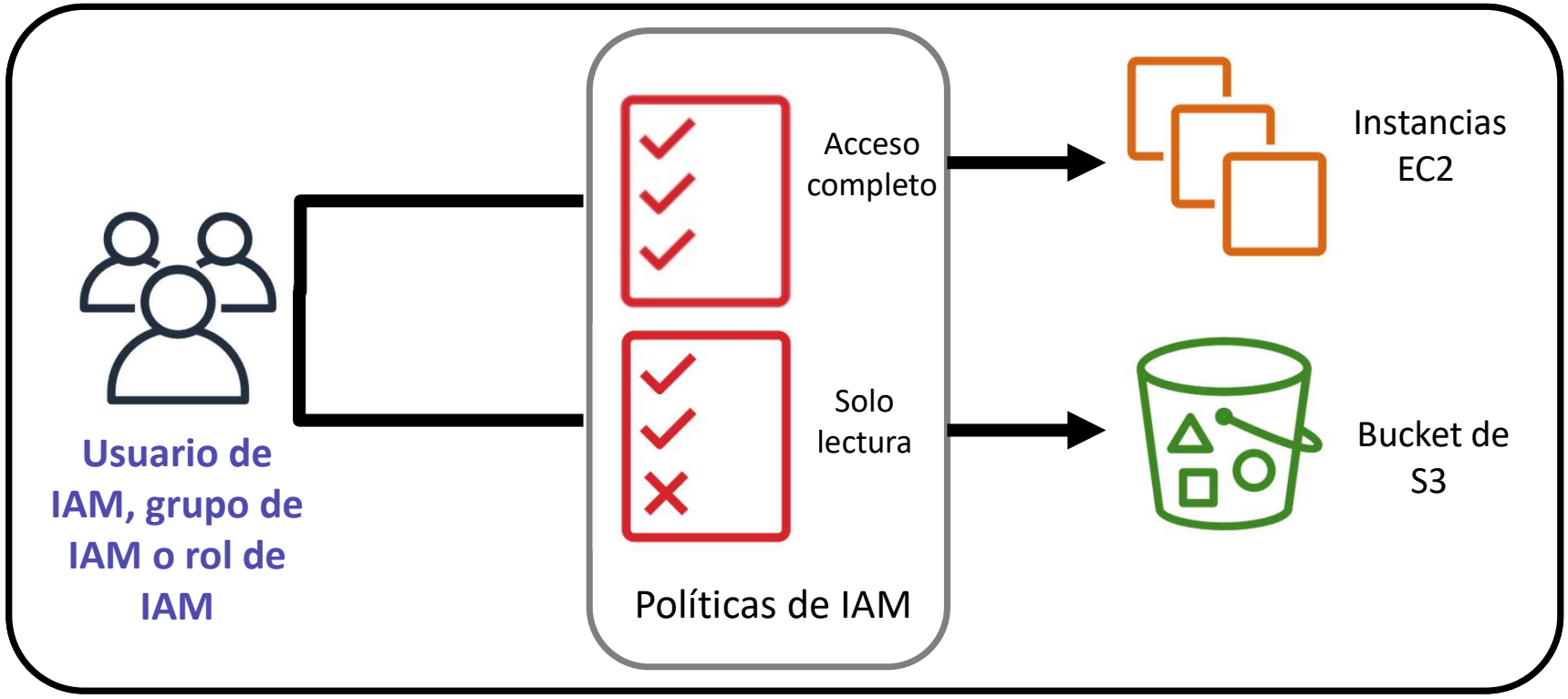


Consola de administración de AWS

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Autorización: qué acciones están permitidas

Una vez que el usuario o la aplicación se haya conectado a la cuenta de AWS, ¿qué pueden hacer?



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

IAM: autorización

- Asigna permisos mediante la creación de una política de IAM.
- Los permisos determinan **qué recursos y operaciones** están permitidas:
  - De forma predeterminada, todos los permisos están denegados implícitamente.
  - Si algo está denegado explícitamente, nunca se permite.

Práctica recomendada: seguir el **principio de mínimo privilegio**.



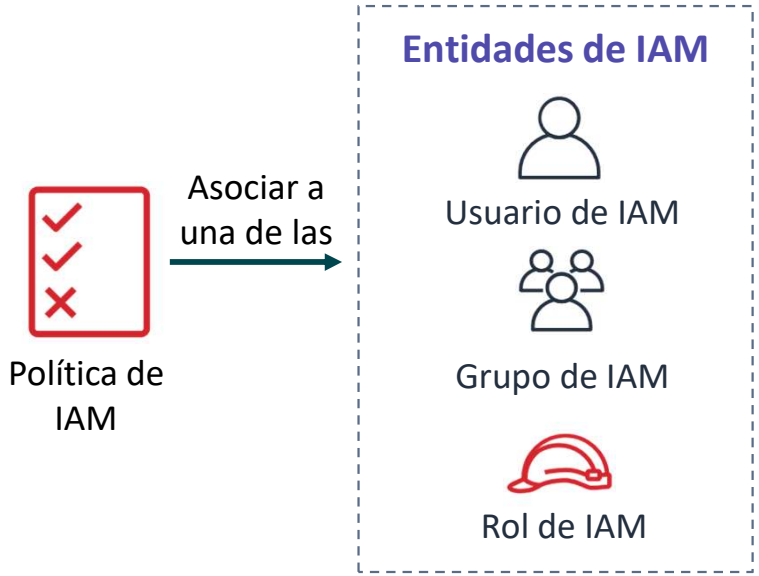
Permisos de IAM

Nota: El alcance de las configuraciones de servicios de IAM es **global**. Las configuraciones se aplican a todas las regiones de AWS.

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Políticas de IAM

- **Una política de IAM es un documento que define permisos.**
  - Habilita el control de acceso detallado.
- Existen dos tipos de políticas: *basadas en identidad* y *basadas en recursos*
- Políticas **basadas en identidad:**
  - Asocian una política a cualquier entidad de IAM.
    - Un usuario de IAM, un grupo de IAM, o un rol de IAM
  - Las políticas especifican lo siguiente:
    - Acciones que ***puede*** realizar la entidad
    - Acciones que la entidad ***no puede*** realizar
  - Una sola *política* se puede asociar a varias *entidades.*
  - Una sola *entidad* puede tener varias *políticas* asociadas a ella.
- Políticas **basadas en recursos**
  - Están asociadas a un recurso (como un bucket de S3).



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Ejemplo de política de IAM

```
{
  "Version": "2012-10-17",
  "Statement":[{
    "Effect":"Allow",
    "Action":["DynamoDB:*","s3:*"],
    "Resource":[
      "arn:aws:dynamodb:region:account-number-without-hyphens:table/table-name",
      "arn:aws:s3:::bucket-name",
      "arn:aws:s3:::bucket-name/*"]
    },
    {
    "Effect":"Deny",
    "Action":["dynamodb:*","s3:*"],
    "NotResource":["arn:aws:dynamodb:region:account-number-without-hyphens:table/table-name”,
      "arn:aws:s3:::bucket-name",
      "arn:aws:s3:::bucket-name/*"]
    }
  ]
}
```

El **permiso explícito** concede a los usuarios acceso a una tabla específica de DynamoDB y a…

…buckets de Amazon S3.

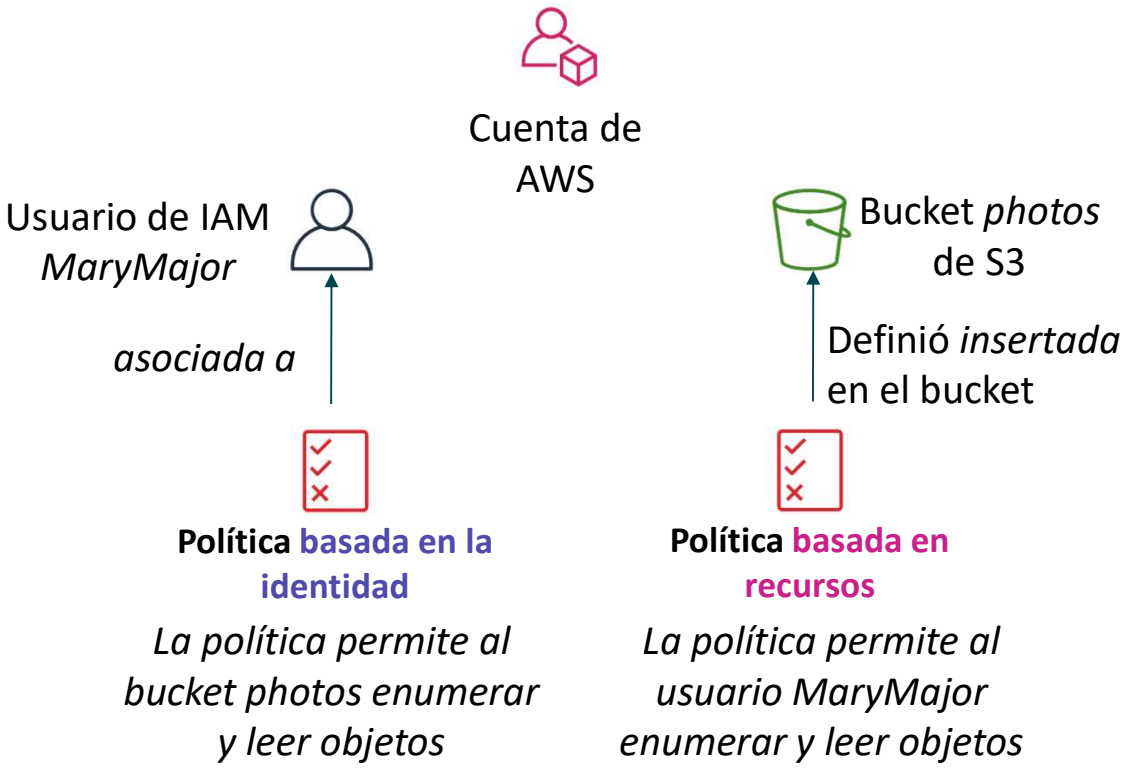
Explicit deny (denegación explícita) garantiza que los usuarios no puedan usar otras acciones o recursos de AWS que no sean esa tabla y esos buckets.

Una instrucción de denegación explícita **prevalece** sobre una instrucción de permiso.

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Políticas basadas en recursos

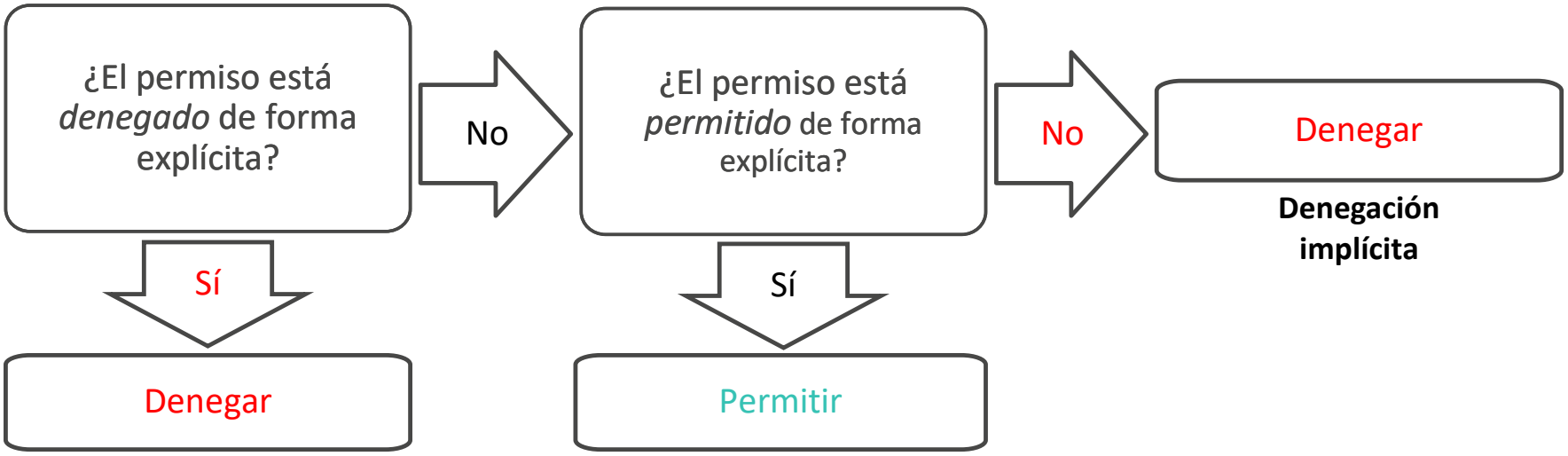
- Las políticas *basadas en identidad* se asocian a un usuario, grupo o rol.
- Las **políticas basadas en recursos** se asocian a un recurso (*no* a un usuario, grupo o rol)
- Características de las políticas basadas en recursos:
  - Especifican quién tiene acceso al recurso y qué acciones se pueden realizar en él.
  - Las políticas son *insertadas* solamente, no se administran.
- Las políticas basadas en recursos solo se admiten en algunos servicios de AWS



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Permisos de IAM

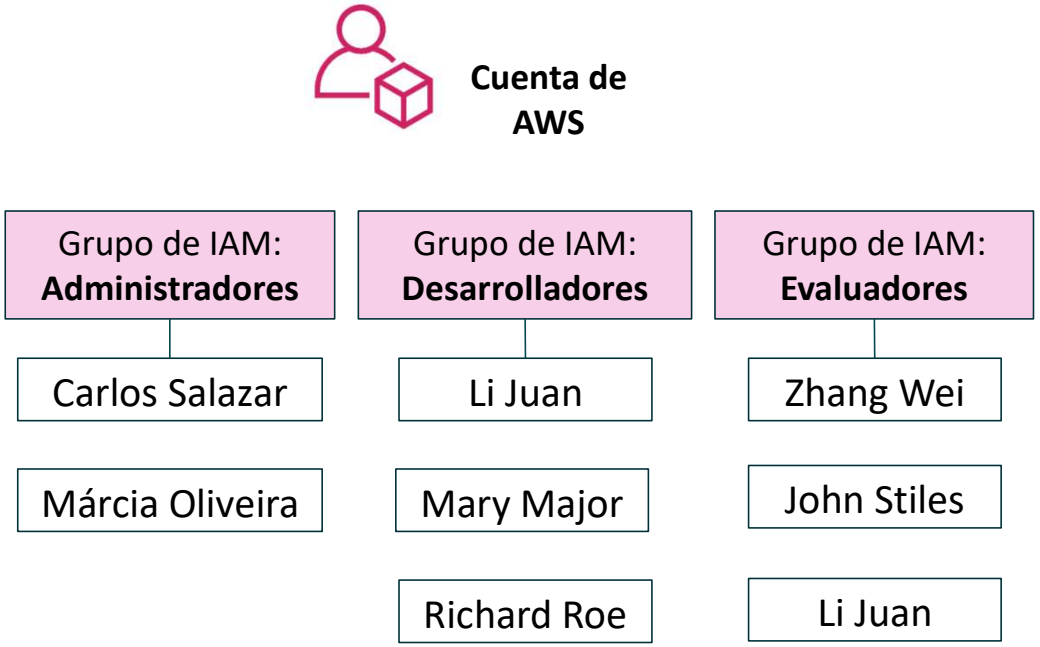
Modo en que IAM determina los permisos:



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Grupos de IAM

- Un **grupo de IAM** es un conjunto de usuarios de IAM.
- Un grupo se utiliza para conceder los mismos permisos a varios usuarios.
  - Se conceden los permisos cuando se asocia la *política* o las políticas de IAM al grupo.
- Un usuario puede pertenecer a varios grupos.
- No hay grupo predeterminado.
- Los grupos no pueden estar anidados.



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Roles de IAM

- Un **rol de IAM** es una identidad de IAM con permisos específicos.
- Es similar a un usuario de IAM
  - Asocia políticas de permisos a él.
- Es diferente a un usuario de IAM.
  - No está asociado de forma exclusiva a una persona.
  - Está diseñado para *que lo pueda asumir* una **persona**, una **aplicación** o un **servicio.**
- El rol proporciona credenciales de seguridad *temporales*.
- Ejemplos de cómo se utilizan los roles de IAM para **delegar** el acceso:
  - Utilizado por un usuario de IAM en la misma cuenta de AWS que utiliza el rol
  - Utilizado por un servicio de AWS, como Amazon EC2, en la misma cuenta que utiliza el rol
  - Utilizado por un usuario de IAM en una cuenta de AWS diferente a la que utiliza el rol



Rol de IAM

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

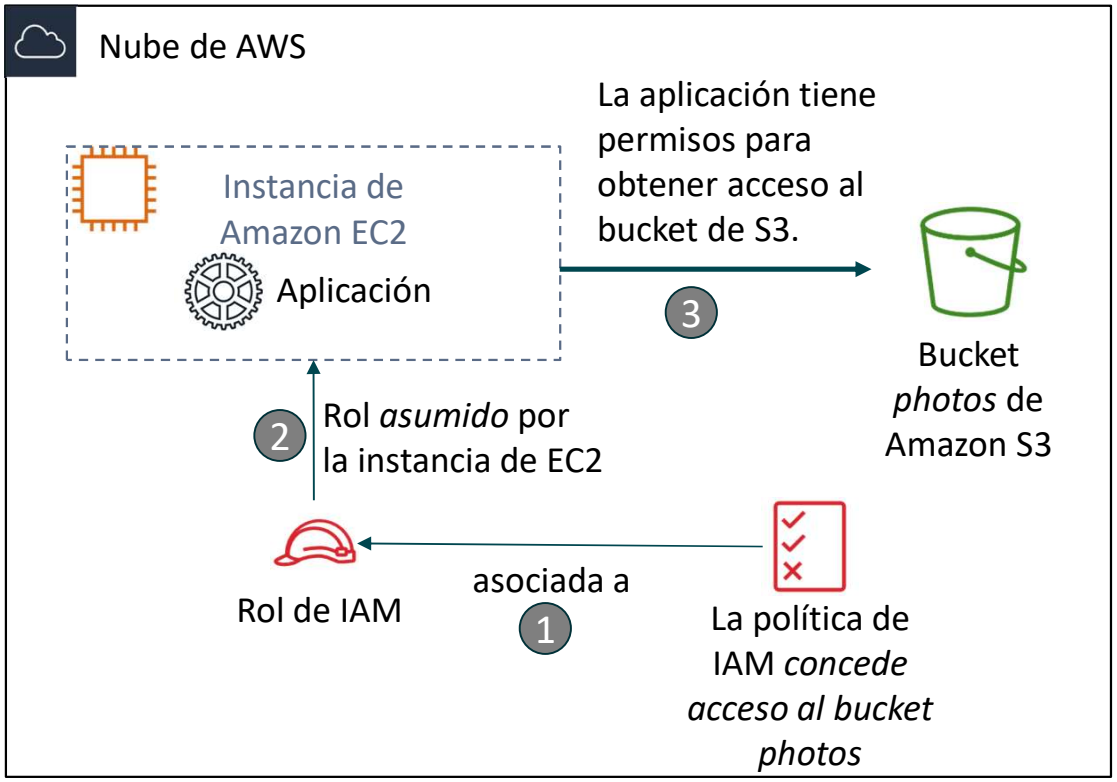
Ejemplo de uso de un rol de IAM

Situación:

- Una aplicación que se ejecuta en una instancia EC2 necesita acceso a un bucket de S3

Solución:

- Definir una política de IAM que conceda acceso al bucket de S3
- Asociar la política a un rol
- Permitir que la instancia EC2 asuma el rol



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Aprendizajes clave de la sección 2



- Las **políticas de IAM** se crean con la notación de objetos JavaScript (JSON) y definen permisos.
  - Las políticas de IAM se pueden asociar a cualquier **entidad de IAM**.
  - Las entidades son usuarios de IAM, grupos de IAM y roles de IAM.
- Un **usuario de IAM** permite que una persona, aplicación o servicio pueda autenticarse en AWS.
- Un **grupo de IAM** permite asociar las mismas políticas a varios usuarios de una manera sencilla.
- Un **rol de IAM** puede tener asociadas políticas de permisos y se puede utilizar para delegar acceso temporal a usuarios o aplicaciones.

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Demostración grabada: IAM



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

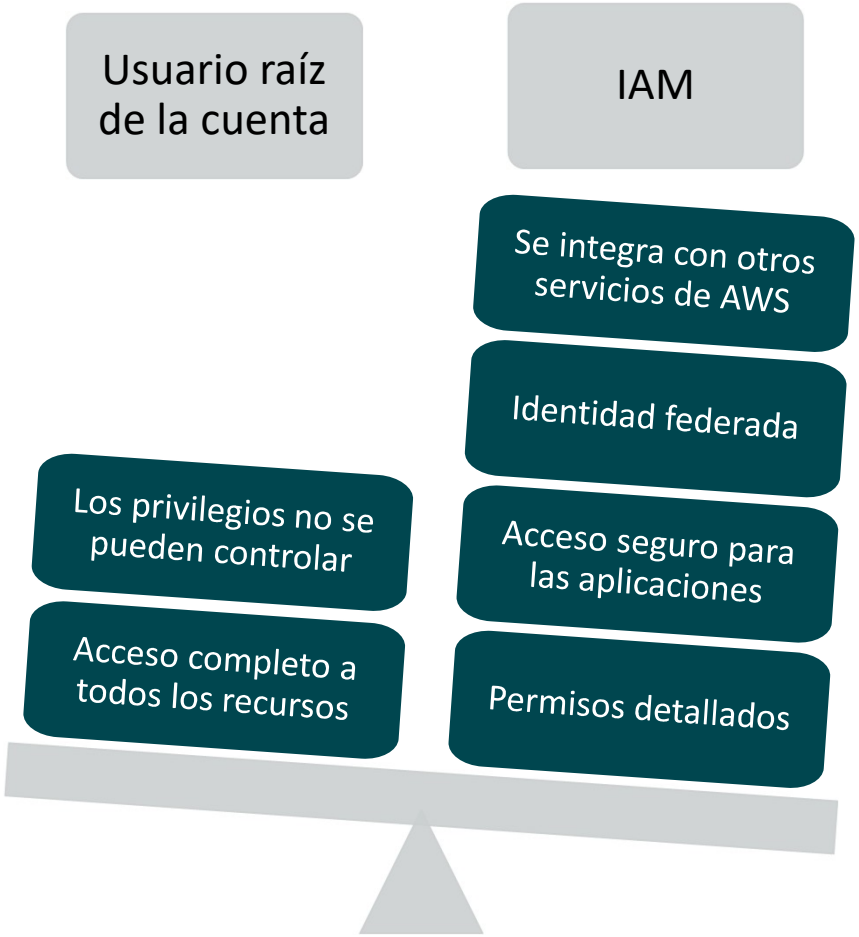
Sección 3: Protección de una cuenta nueva de AWS

Módulo 4: Seguridad en la nube de AWS



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Acceso de usuario raíz de la cuenta de AWS frente al acceso de IAM



- **Práctica recomendada**: no utilice el usuario raíz de la cuenta de AWS, excepto cuando sea necesario.
  - Para acceder al **usuario raíz de la cuenta**, se requiere iniciar sesión con la *dirección de email* (y la contraseña) que utilizó para crear la cuenta.
- Ejemplos de acciones que solo se pueden realizar con el usuario raíz de la cuenta:
  - Actualizar la contraseña del usuario raíz de la cuenta
  - Cambiar el plan de AWS Support
  - Restaurar los permisos de un usuario de IAM
  - Cambiar la configuración de la cuenta (por ejemplo, la información de contacto o las regiones permitidas)

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Protección de una nueva cuenta de AWS: usuario raíz de la cuenta

Paso 1: Deje de utilizar el usuario raíz de la cuenta tan pronto como sea posible.

- El usuario raíz de la cuenta tiene acceso ilimitado a todos sus recursos.

- Pasos a seguir para dejar de utilizar el usuario raíz de la cuenta:
  1. Inicie sesión como usuario raíz de la cuenta y cree un usuario de IAM para usted. Guarde las claves de acceso si es necesario.
  2. Cree un grupo de IAM, otórguele permisos totales de administrador y agregue el usuario de IAM al grupo.
  3. Deshabilite y elimine las claves de acceso de usuario raíz de la cuenta, en caso de que existan.
  4. Habilite una política de contraseñas para los usuarios.
  5. Inicie sesión con sus nuevas credenciales de usuario de IAM.
  6. Guarde las credenciales de usuario raíz de la cuenta en un lugar seguro.

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Protección de una nueva cuenta de AWS: MFA

Paso 2: Habilite Multi-Factor Authentication (MFA).

- Exija MFA para su usuario raíz de la cuenta y para todos los usuarios de IAM.
- También puede usar MFA para controlar el acceso a las API de servicio de AWS.

- Opciones para recuperar el token de MFA:
  - Aplicaciones virtuales compatibles con MFA:
    - Google Authenticator
    - Authy Authenticator (aplicación de Windows Phone)
  - Dispositivos de clave de seguridad U2F:
    - Por ejemplo, YubiKey.
  - Opciones de MFA de hardware:
    - Llavero o tarjeta de visualización ofrecida por Gemalto.



Token de MFA

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Protección de una nueva cuenta de AWS: AWS CloudTrail

Paso 3: Utilice AWS CloudTrail.

- CloudTrail realiza un seguimiento de la actividad de los usuarios en su cuenta.
  - Registra todas las solicitudes API para los recursos de todos los servicios admitidos de su cuenta.
- El historial básico de eventos de AWS CloudTrail está habilitado de forma predeterminada y es gratuito.
  - Contiene todos los datos de eventos de administración de los últimos 90 días de actividad de la cuenta.
- Pasos a seguir para obtener acceso a CloudTrail:
  1. Inicie sesión en la **consola de administración de AWS** y seleccione el servicio **CloudTrail**.
  2. Haga clic en **Event history** (Historial de eventos) para ver, filtrar y buscar los últimos 90 días de eventos.
- **Para habilitar los registros de más de 90 días y las alertas de eventos especificados, cree un registro de seguimiento.**
  1. En la página de registros de seguimiento de la consola de CloudTrail, haga clic en **Create trail** (Crear registro de seguimiento).
  2. Asígnele un nombre, aplíquelo a todas las regiones y cree un nuevo bucket de Amazon S3 para el almacenamiento de registros.
  3. Configure las restricciones de acceso en el bucket de S3 (por ejemplo, solo los usuarios administradores deben tener acceso).

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Protección de una nueva cuenta de AWS: informes de facturación

Paso 4: Habilite un informe de facturación, **como el informe de uso y costo de AWS**.

- Los informes de facturación proporcionan información sobre el uso de los recursos de AWS y los costos estimados de dicho uso.
- AWS entrega los informes en el bucket de Amazon S3 que especifique.
    - El informe se actualiza al menos una vez al día.
- El **Informe de uso y costo de AWS** hace un seguimiento del uso que hace de AWS y proporciona cargos estimados asociados con su cuenta de AWS, ya sea por hora o por día.

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Opcional: Protección de una nueva cuenta de AWS (explicación completa)

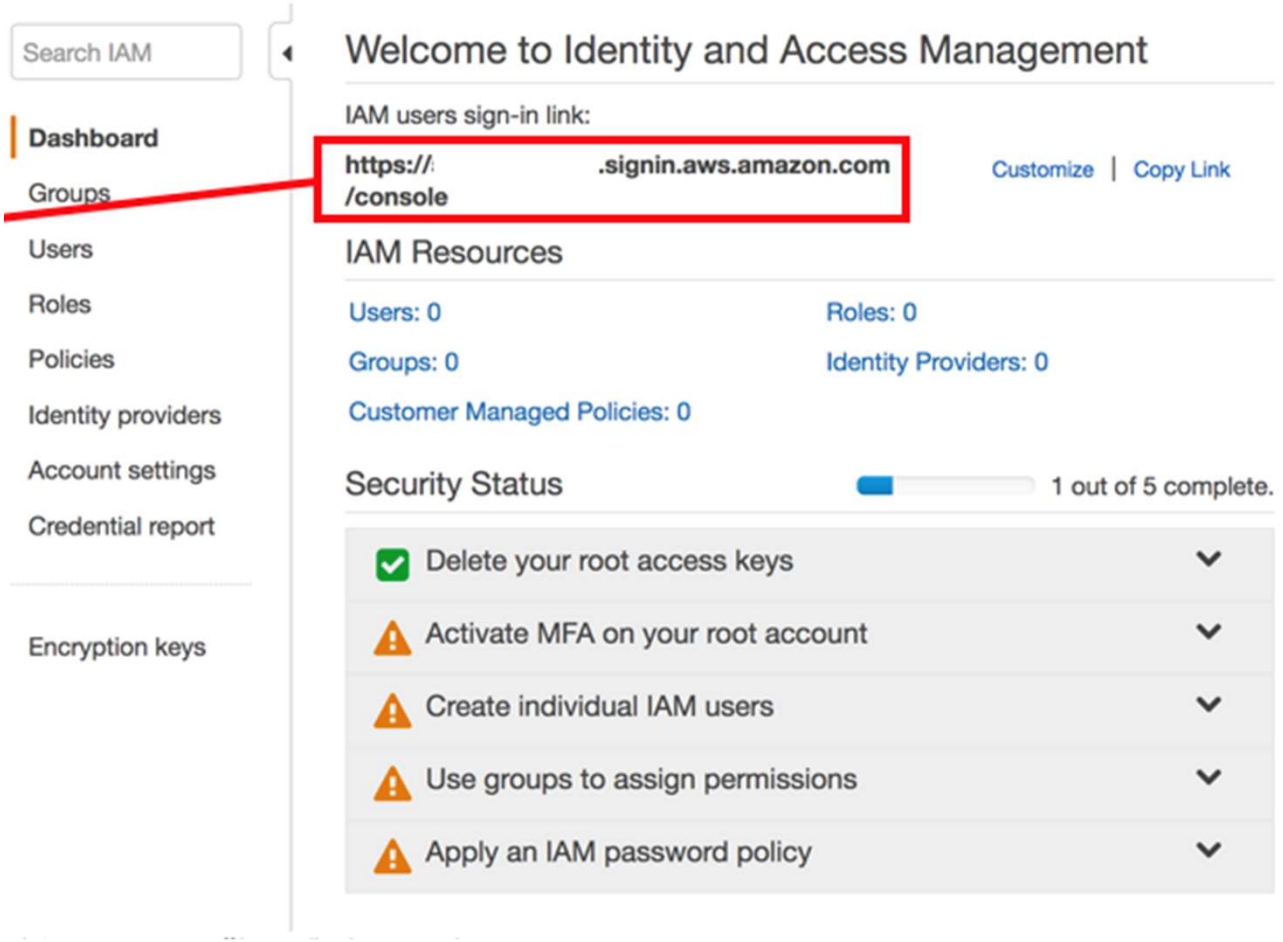
Módulo 4: Seguridad en la nube de AWS



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Revisión del estado de seguridad de IAM

Enlace de inicio de sesión personalizado

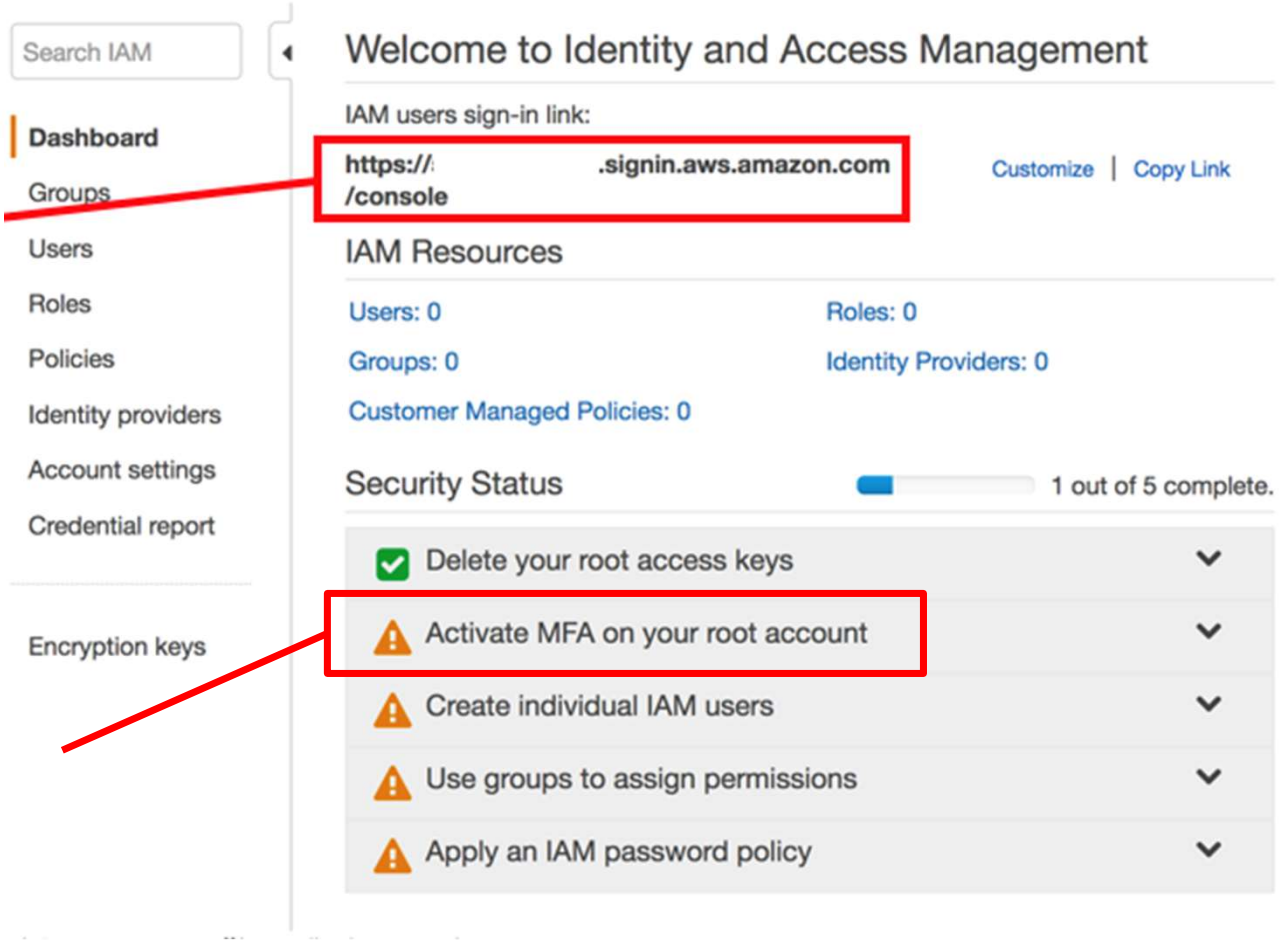


© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Activar MFA en el usuario raíz de la cuenta

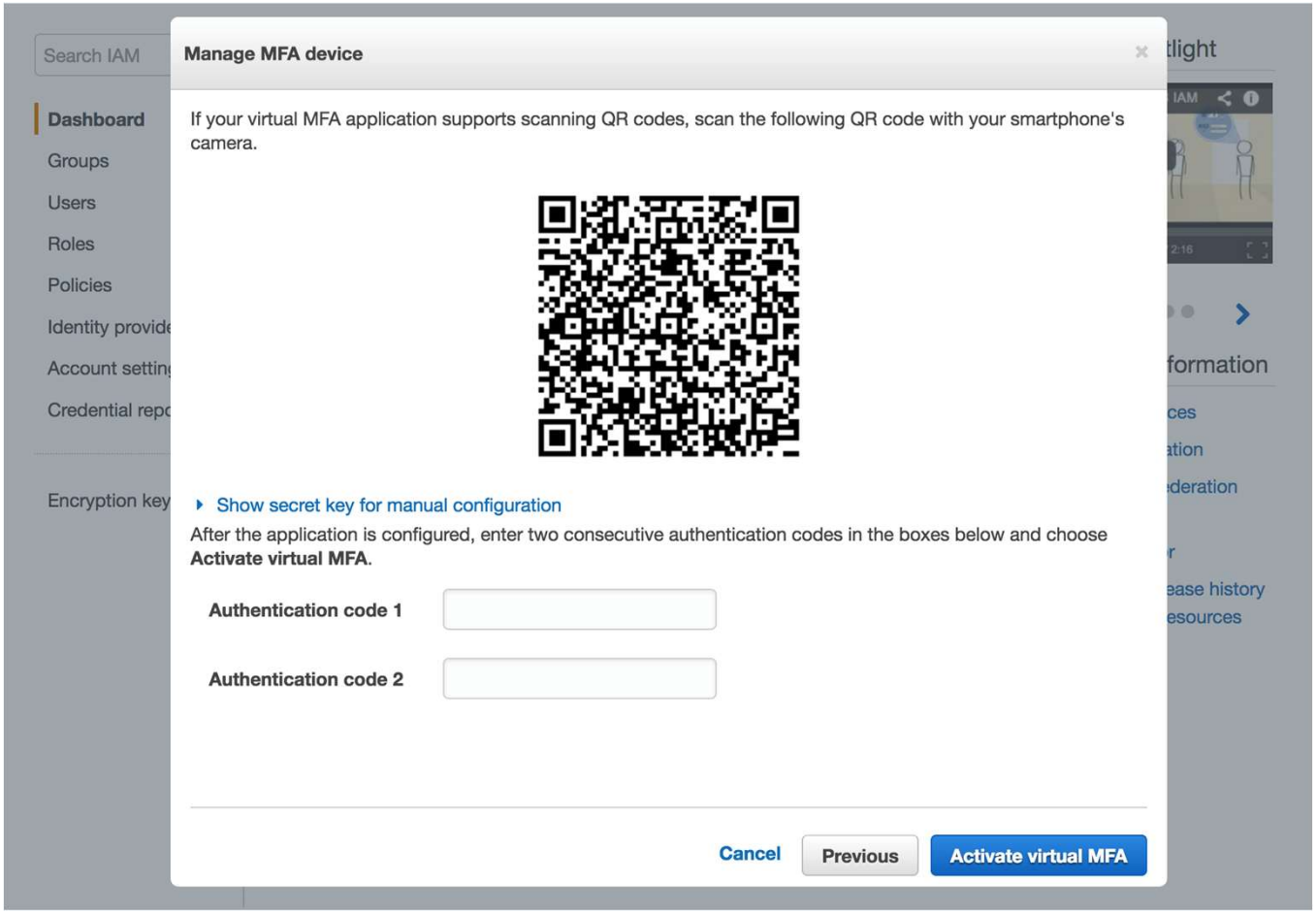
Enlace de inicio de sesión personalizado

Activación de MFA



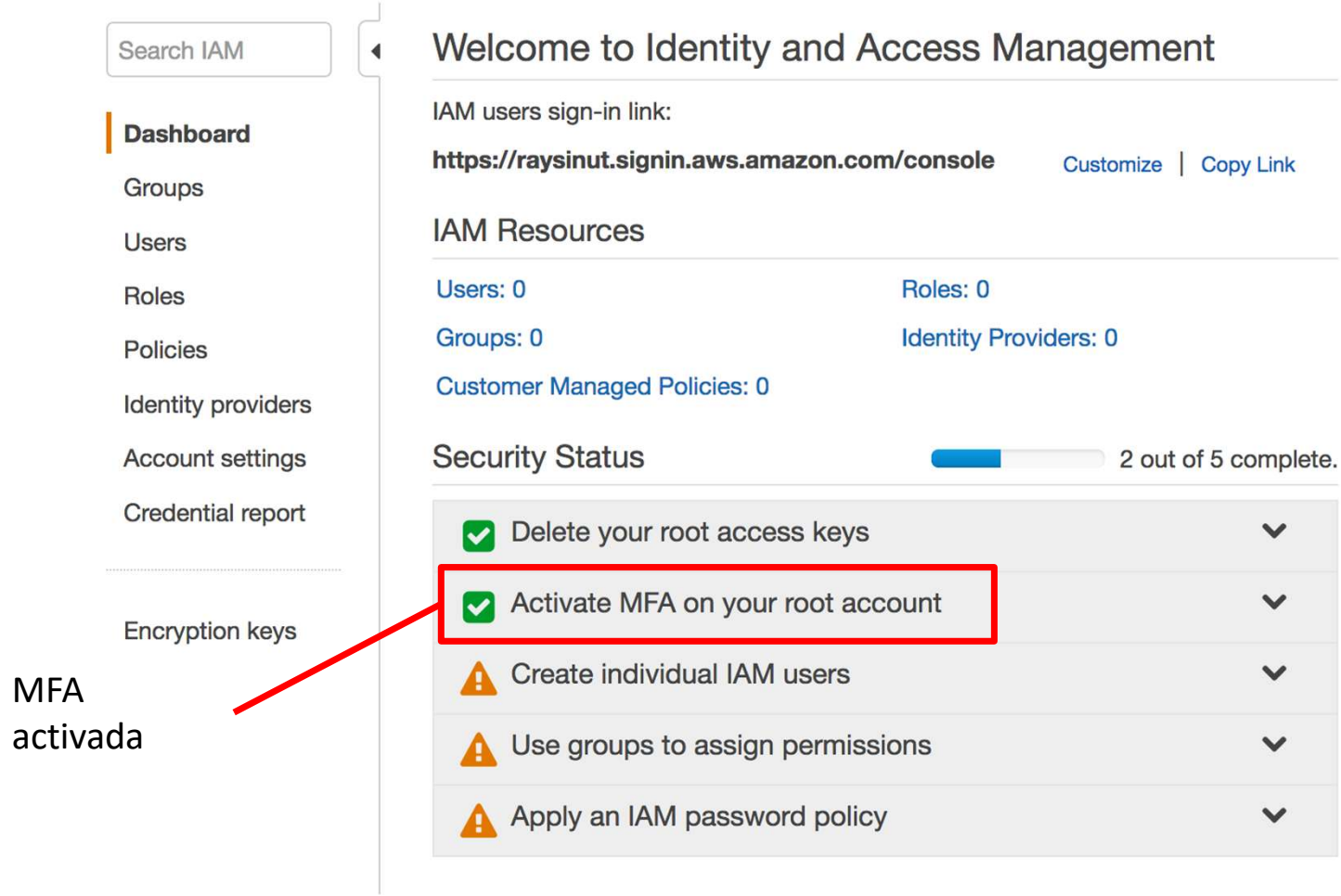
© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Activar MFA en el usuario raíz de la cuenta



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

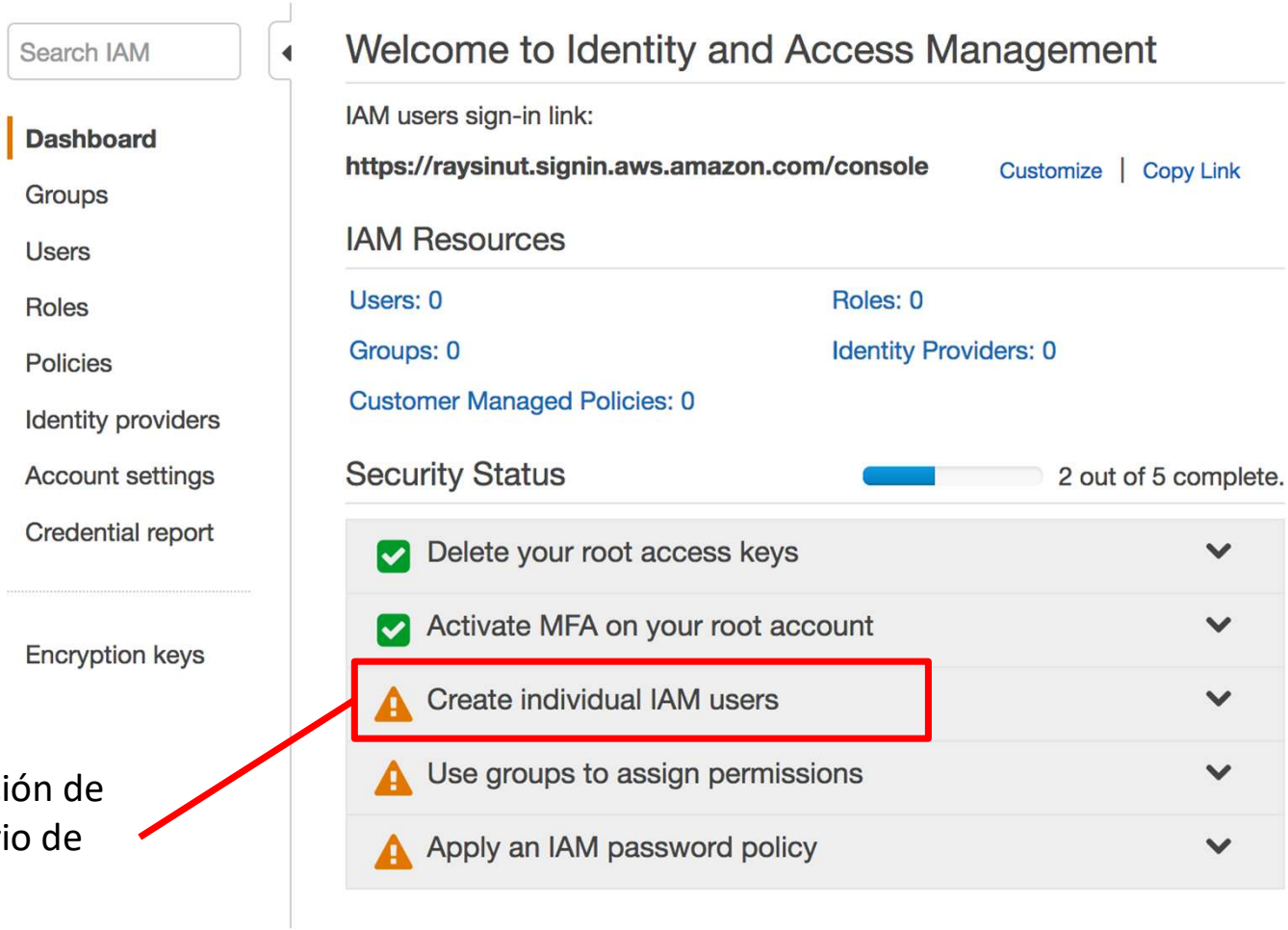
MFA en el usuario raíz de la cuenta está activado



MFA activada

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

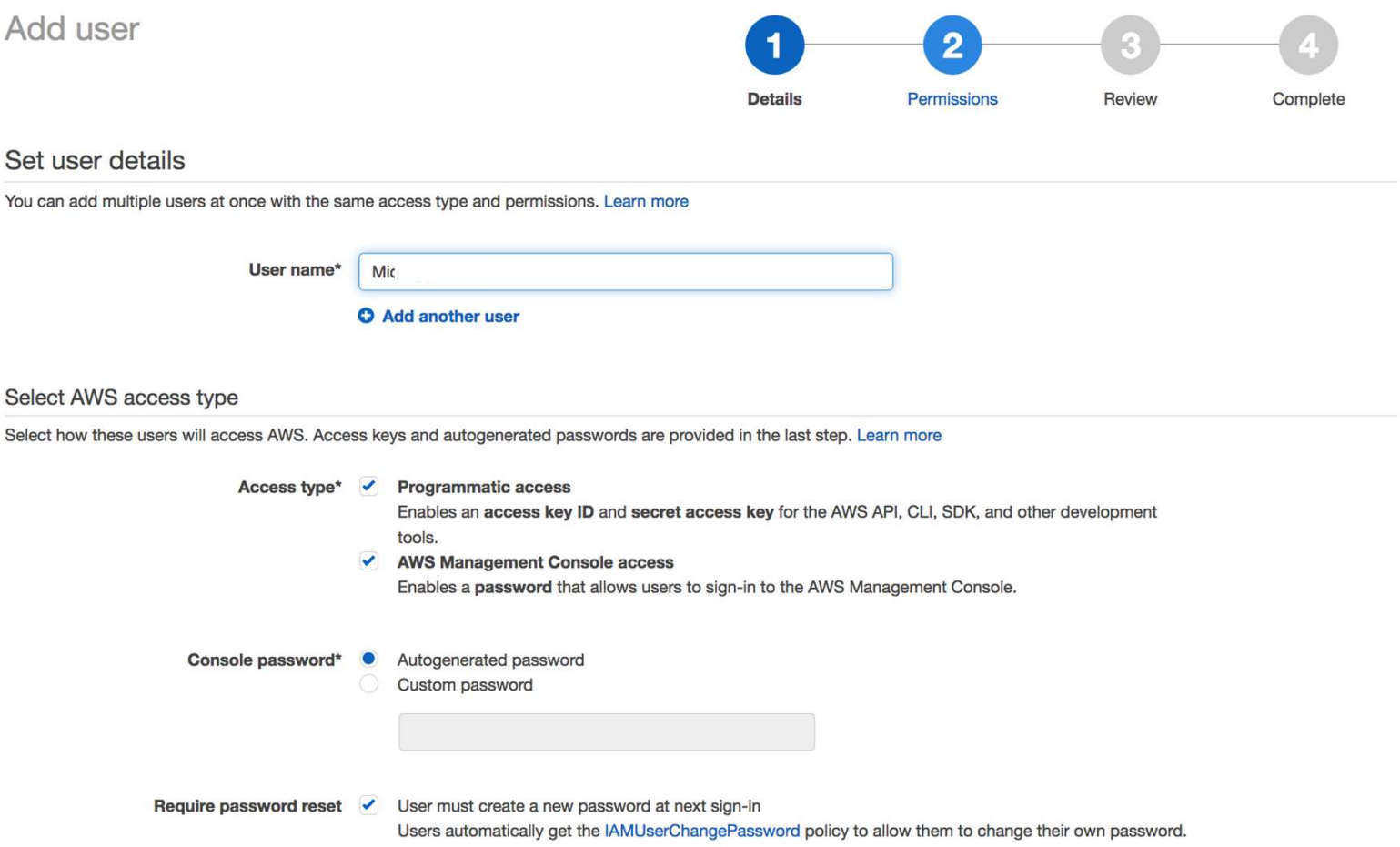
Crear un usuario individual de IAM (1)



Creación de usuario de IAM

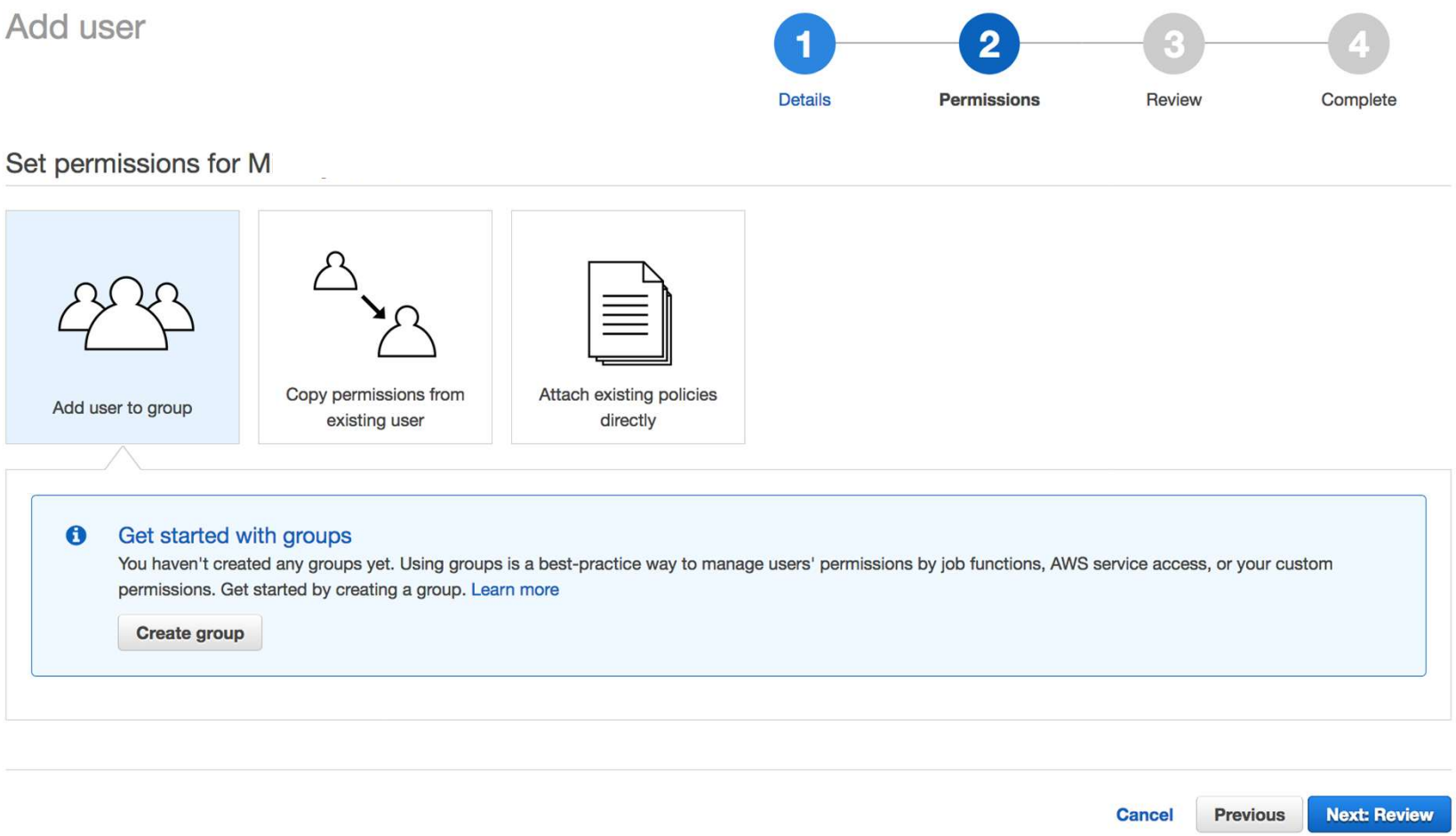
© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Crear un usuario individual de IAM (2)



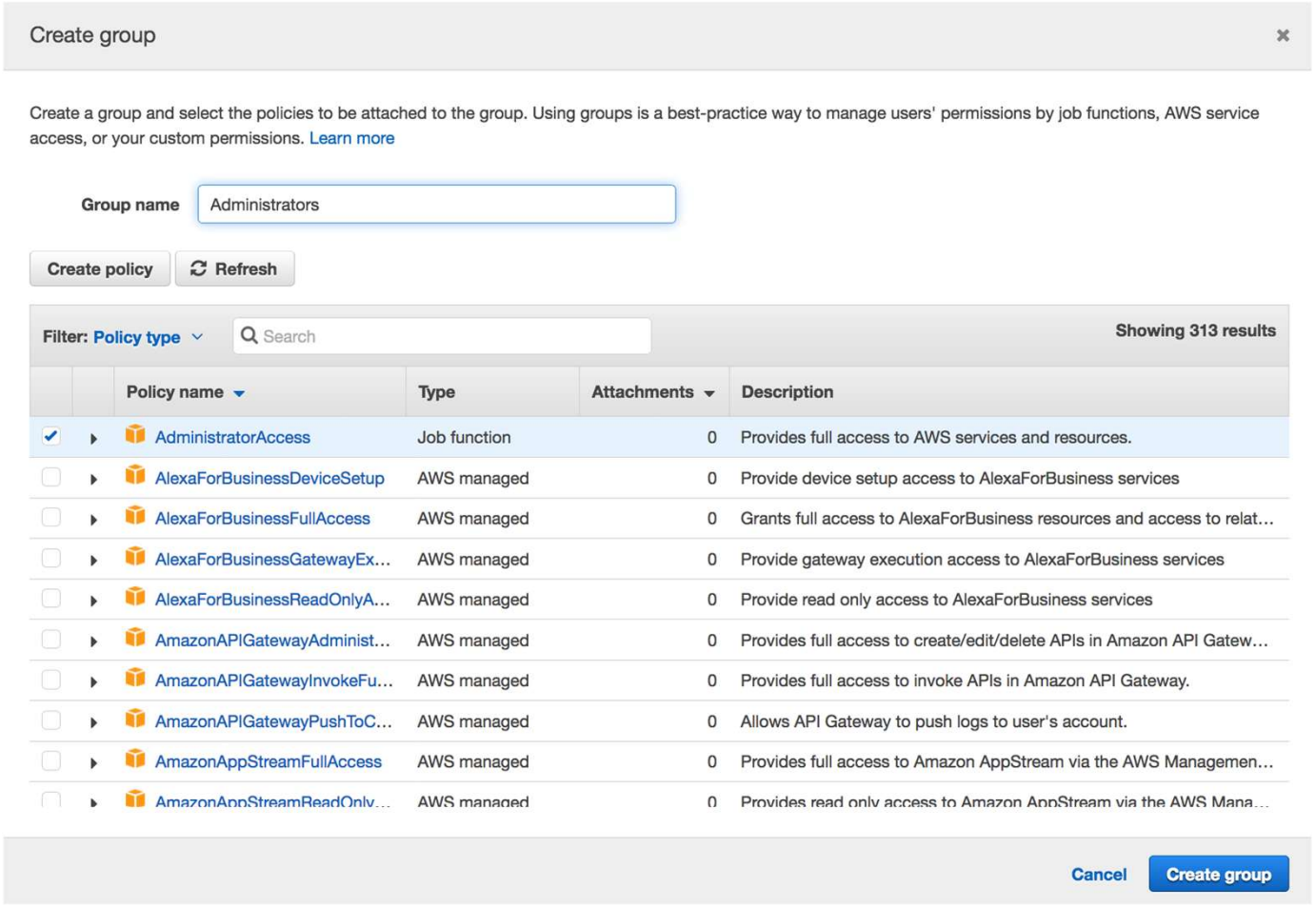
© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Crear un usuario individual de IAM (3)



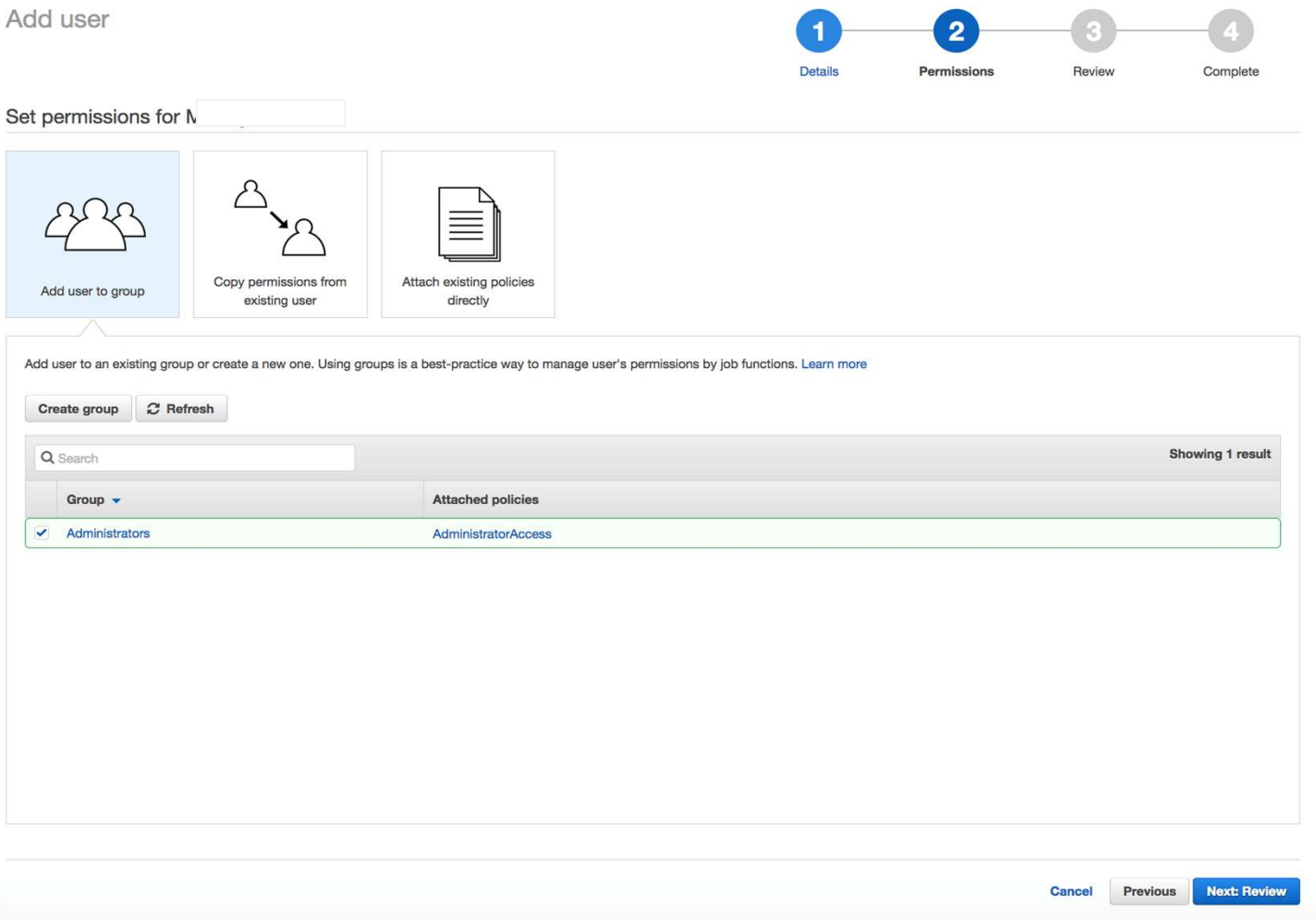
© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Crear un usuario individual de IAM (4)



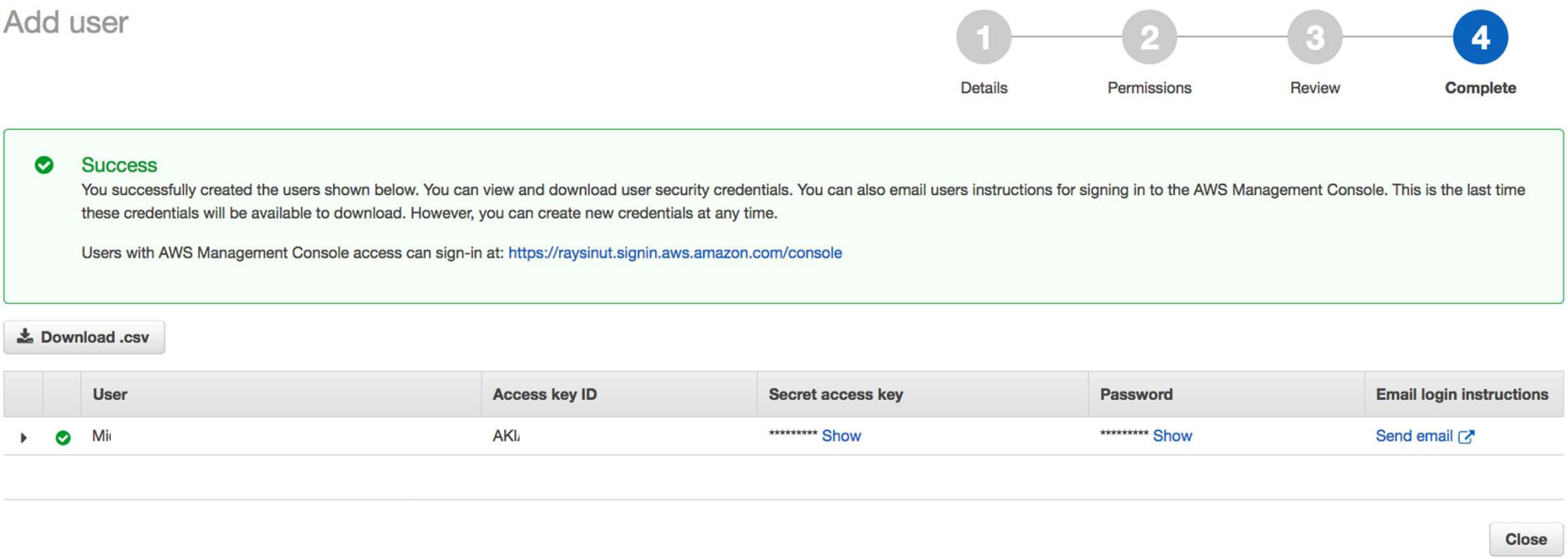
© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Crear un usuario individual de IAM (5)



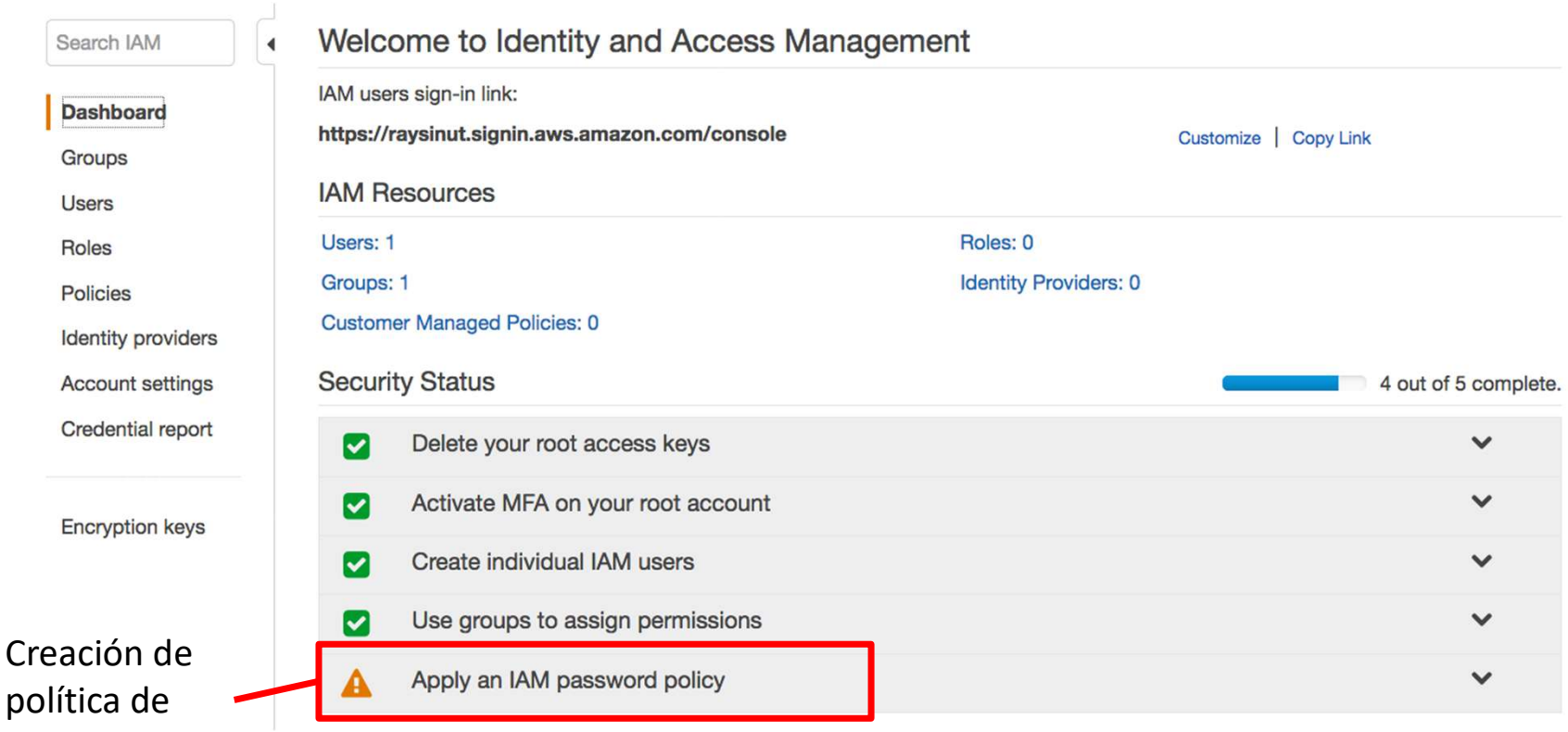
© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Creación exitosa de usuario de IAM



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

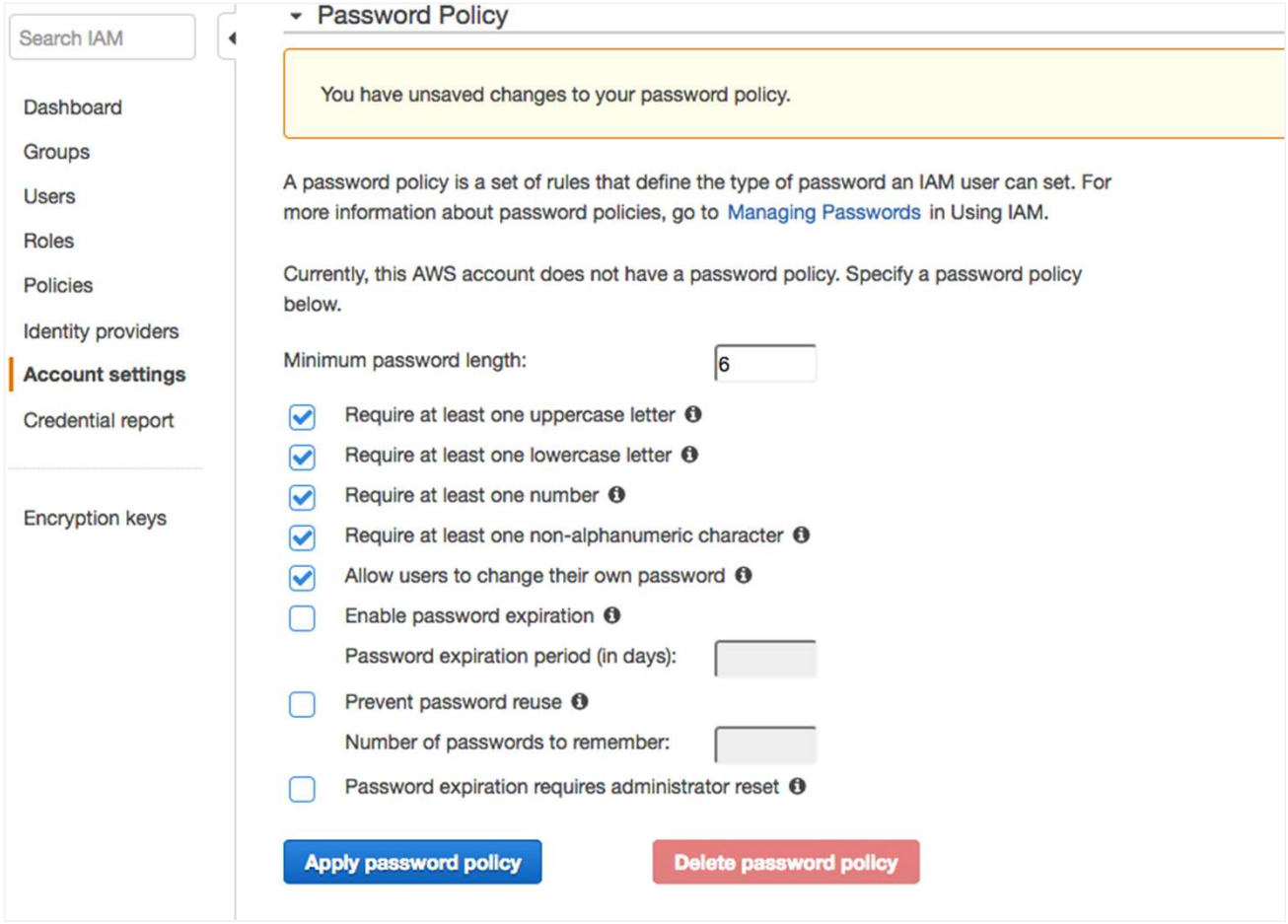
Estado de seguridad del panel de IAM



Creación de política de contraseñas

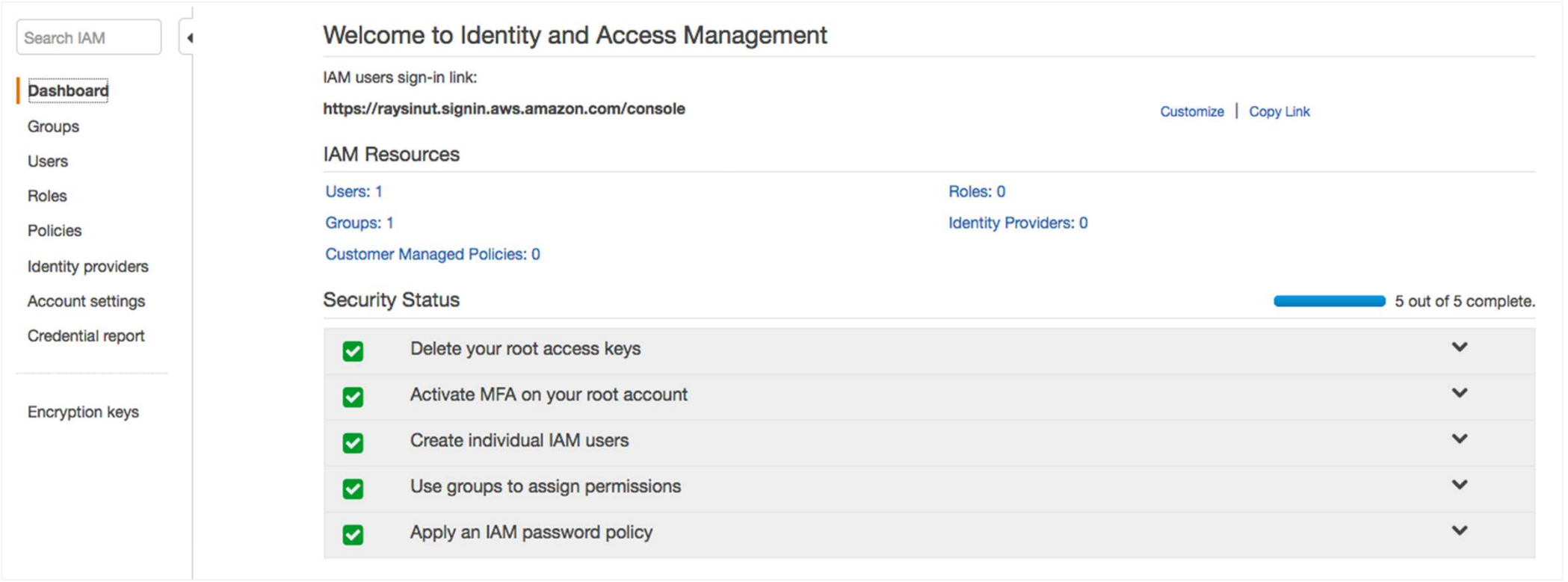
© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Establecer una política de contraseñas de IAM



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Comprobaciones de estado de seguridad completadas



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Aprendizajes clave de la sección 3

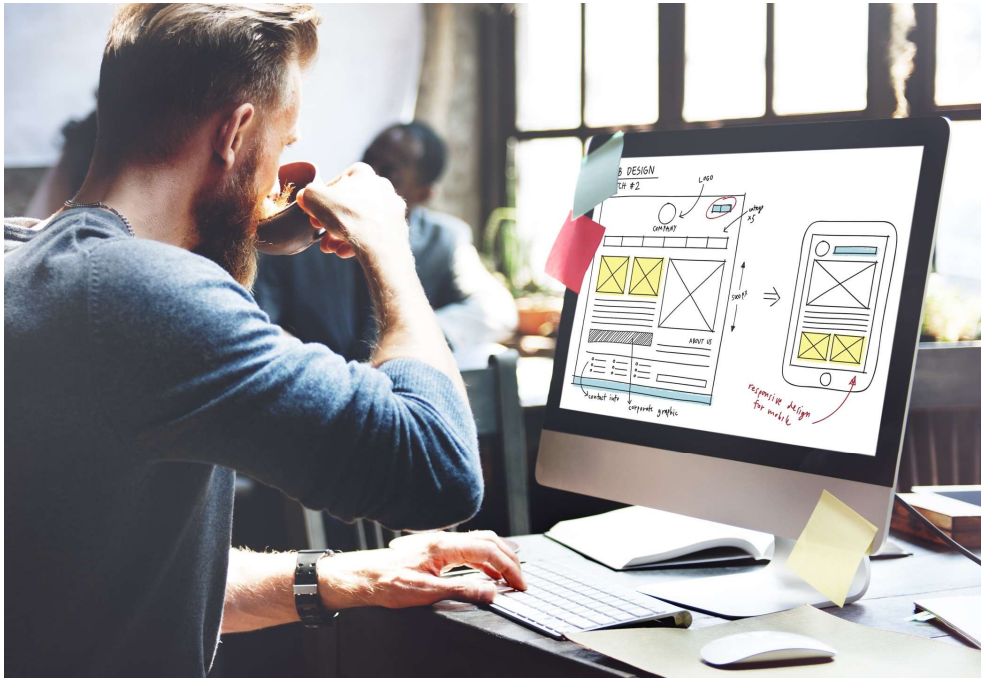


Prácticas recomendadas para proteger una cuenta de AWS:

- **Proteja** los inicios de sesión con Multi-Factor Authentication (MFA).
- **Elimine** las claves de acceso de usuario raíz de la cuenta.
- **Cree** usuarios de IAM individuales y otorgue permisos de acuerdo con el principio de mínimo privilegio.
- **Utilice grupos** para asignar permisos a usuarios0 de IAM.
- **Configure** una política de contraseñas sólida.
- **Delegue** el uso de roles en lugar del uso compartido de credenciales.
- **Monitoree** la actividad de la cuenta mediante AWS CloudTrail.

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Laboratorio 1: Introducción a IAM



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Laboratorio 1: tareas

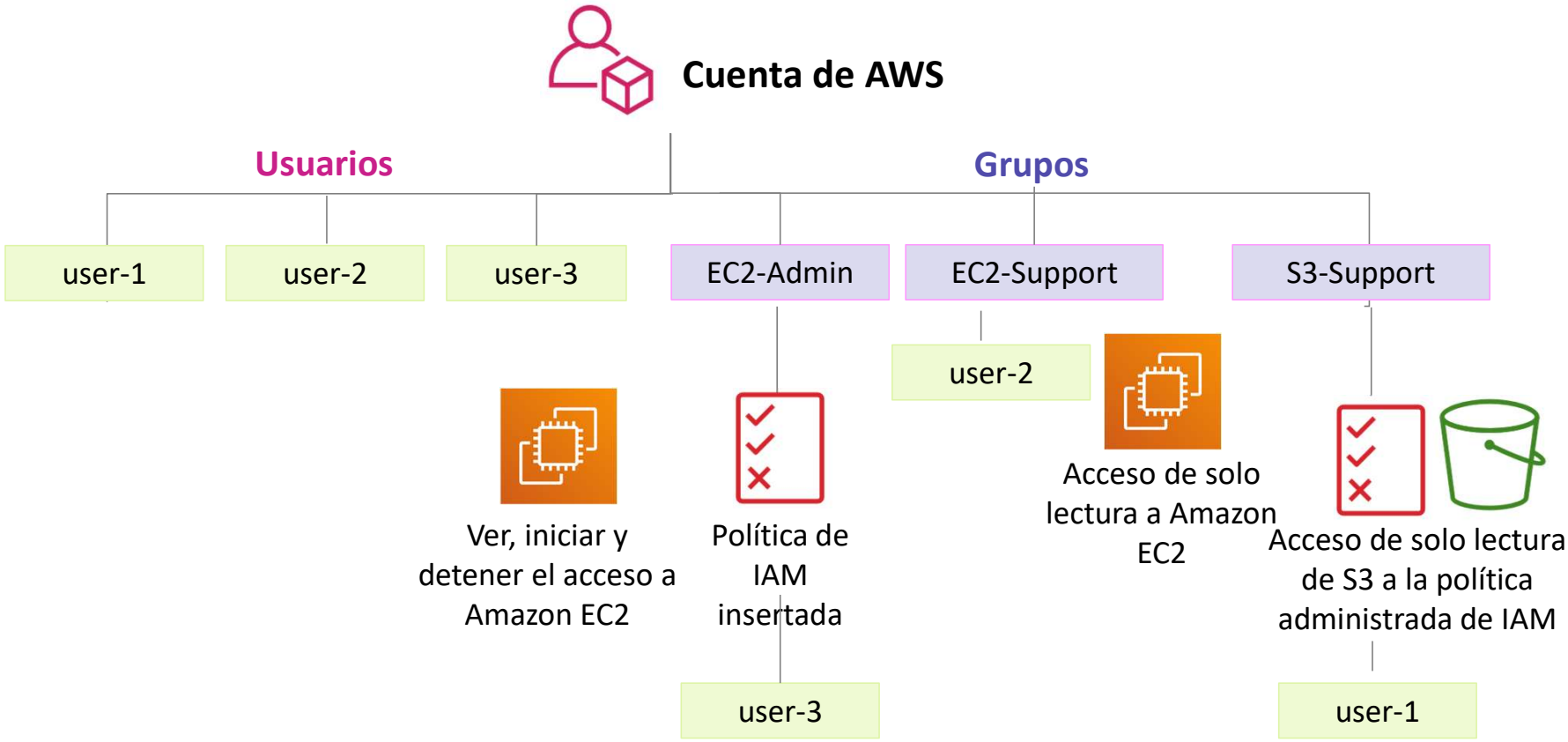
- Tarea 1: analizar los usuarios y los grupos
- Tarea 2: agregar usuarios a los grupos
- Tarea 3: iniciar sesión y probar los usuarios



AWS Identity and Access Management (IAM)

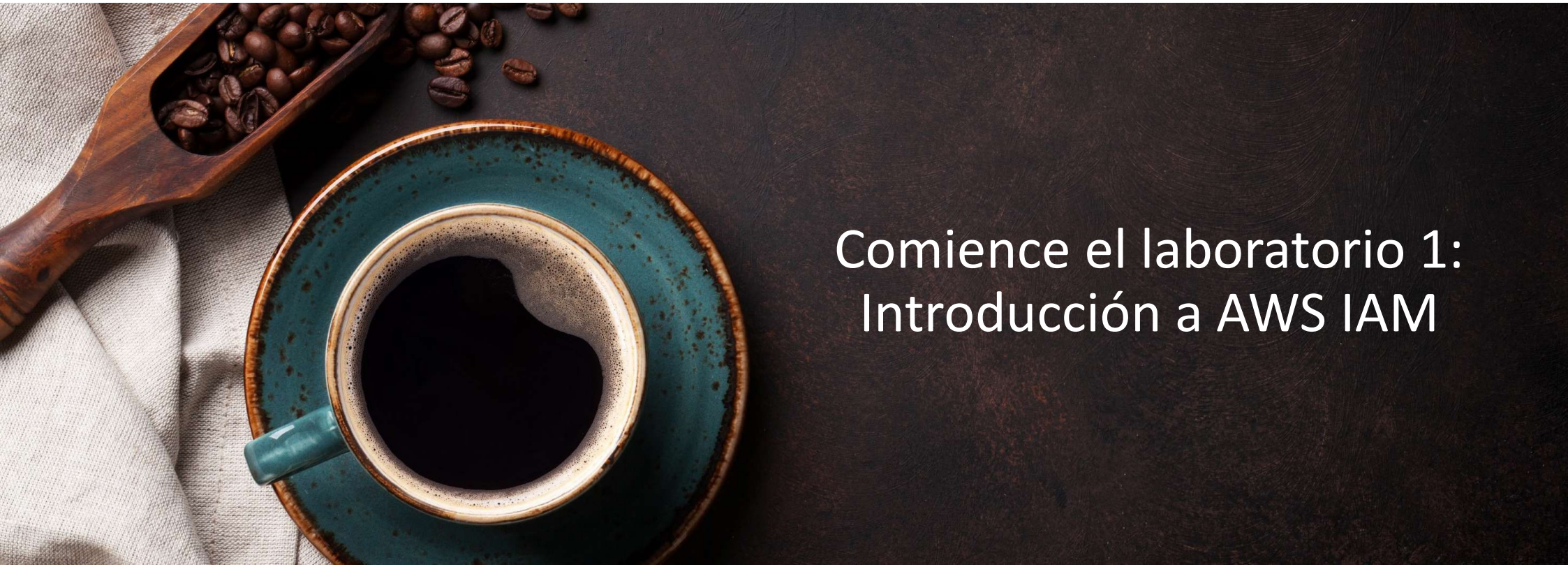
© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Laboratorio 1: producto final



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

~ 40 minutes



Comience el laboratorio 1: Introducción a AWS IAM

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Análisis posterior del laboratorio: aprendizajes clave



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Sección 4: Protección de cuentas

Módulo 4: Seguridad en la nube de AWS



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

AWS Organizations

- **AWS Organizations** le permite consolidar varias cuentas de AWS para que las administre de forma centralizada.



AWS Organizations

- Características de seguridad de AWS Organizations:
  - **Agrupa las cuentas de AWS en unidades organizativas** (OU) y asocian las diferentes políticas de acceso a cada una de ellas.
  - **Permite integración y compatibilidad con IAM.**
    - Los permisos para un usuario son la intersección de lo que AWS Organizations permite y lo que IAM concede en esa cuenta.
  - **Utiliza políticas de control de servicios** para establecer el control sobre las acciones de API y los servicios de AWS a los que cada cuenta de AWS puede obtener acceso.

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

AWS Organizations: política de control de servicios

- Las **políticas de control de servicios (SCP)** ofrecen control centralizado sobre las cuentas.
  - Limita los permisos disponibles en una cuenta que forma parte de la organización.
- Garantiza que las cuentas cumplan con las directrices de control de acceso.
- Las SCP son *similares* a las políticas de permisos de IAM:
  - Utilizan una sintaxis similar.
  - Sin embargo, una SCP nunca concede permisos.
  - En su lugar, las SCP especifican los permisos máximos para una organización.

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

AWS Key Management Service (AWS KMS)

Características de **AWS Key Management Service (AWS KMS)**:

- Le permite **crear y administrar claves de cifrado**.
- Le permite controlar el uso del cifrado en los servicios de AWS y en sus aplicaciones.
- Se integra con AWS CloudTrail para registrar el uso de todas las claves.
- Utiliza módulos de seguridad de hardware (HSM) validados por *Federal Information Processing Standards* (FIPS, Estándar de procesamiento de la información federal) 140-2 para proteger las claves.



AWS Key Management Service (AWS KMS)

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Amazon Cognito

Características de **Amazon Cognito**:

- **Incorpora control de acceso, inicio de sesión y registro de usuarios a sus aplicaciones web y móviles**.
- Escala a millones de usuarios.
- Admite el inicio de sesión con proveedores de identidad social, como Facebook, Google y Amazon; y proveedores de identidades empresariales, como Microsoft Active Directory a través del lenguaje de marcado para confirmaciones de seguridad (SAML) 2.0.



Amazon Cognito

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

AWS Shield

- Características de **AWS Shield**:
  - Es un servicio administrado de protección contra ataques de denegación de servicio distribuidos (DDoS).
  - Protege las aplicaciones que se ejecutan en AWS.
  - Proporciona detección permanente y mitigaciones directas automáticas.
    - Se puede habilitar *AWS Shield Standard* sin costo adicional. *AWS Shield Advanced* es un servicio de pago opcional.
- Utilícelo para **minimizar el tiempo de inactividad y la latencia de la aplicación.**



AWS Shield

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Sección 5: Protección de datos en AWS

Módulo 4: Seguridad en la nube de AWS



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Cifrado de datos *en reposo*

- El **cifrado** codifica los datos con una clave secreta, lo que hace que sean ilegibles.
  - Solo aquellos que tienen la clave secreta pueden descodificar los datos.
  - AWS KMS puede administrar sus claves secretas.



- AWS admite el cifrado de **datos en reposo**.
  - Datos en reposo = datos almacenados físicamente (en disco o en cinta)
  - Puede cifrar los datos almacenados en cualquier servicio compatible con AWS KMS, como los siguientes:
    - Amazon S3
    - Amazon EBS
    - Amazon Elastic File System (Amazon EFS)
    - Bases de datos administradas de Amazon RDS





© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Cifrado de datos *en tránsito*

- Cifrado de **datos en tránsito** (datos que migran a través de una red)
  - **Transport Layer Security (TLS)**, anteriormente SSL, es un protocolo estándar abierto.
  - **AWS Certificate Manager** ofrece una forma de administrar, implementar y renovar certificados TLS o SSL
- HTTP seguro (HTTPS) crea un túnel seguro.
  - Utiliza TLS o SSL para el intercambio bidireccional de datos.
- **Los servicios de AWS admiten el cifrado de datos en tránsito**.
  - Dos ejemplos:





© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Protección de buckets y objetos de Amazon S3

- Los buckets y objetos de S3 recientemente creados son privados y están protegidos de forma predeterminada.
- Cuando los casos de uso requieren compartir objetos de datos en Amazon S3:
  - Es fundamental administrar y controlar el acceso a los datos.
  - Siga los **permisos que siguen el principio de privilegio mínimo** y considere la posibilidad de utilizar el cifrado de Amazon S3.
- Entre las herramientas y opciones para controlar el acceso a los datos de S3 se incluyen las siguientes:
  - Característica de Amazon S3 Block Public Access: es fácil de usar.
  - Políticas de IAM: son una buena opción cuando el usuario puede autenticarse con IAM.
  - Políticas de buckets
  - Listas de control de acceso (ACL): son un mecanismo de control de acceso heredado.
- Comprobación de permisos del bucket de AWS Trusted Advisor: es una característica gratuita.

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Sección 6: Trabajo para garantizar la conformidad

Módulo 4: Seguridad en la nube de AWS



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Programas de conformidad de AWS

- Los clientes están sujetos a diferentes reglamentos y requisitos de seguridad y conformidad.
- **AWS colabora con organismos de certificación y auditores independientes para ofrecer a los clientes información detallada sobre las políticas, los procesos y los controles que establece y aplica AWS.**

- Los programas de conformidad pueden clasificarse en las siguientes categorías generales:
  - **Certificaciones y acreditaciones**
    - Evaluadas por un auditor de terceros independiente
    - Ejemplos: ISO 27001, 27017, 27018 e ISO/IEC 9001



  - **Leyes, regulaciones y privacidad**
    - AWS ofrece características de seguridad y acuerdos legales para respaldar la conformidad
    - Ejemplos: Reglamento General de Protección de Datos (GDPR) de la UE, HIPAA



  - **Alineaciones y marcos de trabajo**
    - Requisitos de conformidad o seguridad específicos de cada sector o función
    - Ejemplos: Centro de seguridad en Internet (CIS), certificado por el Escudo de la privacidad UE-EE. UU.



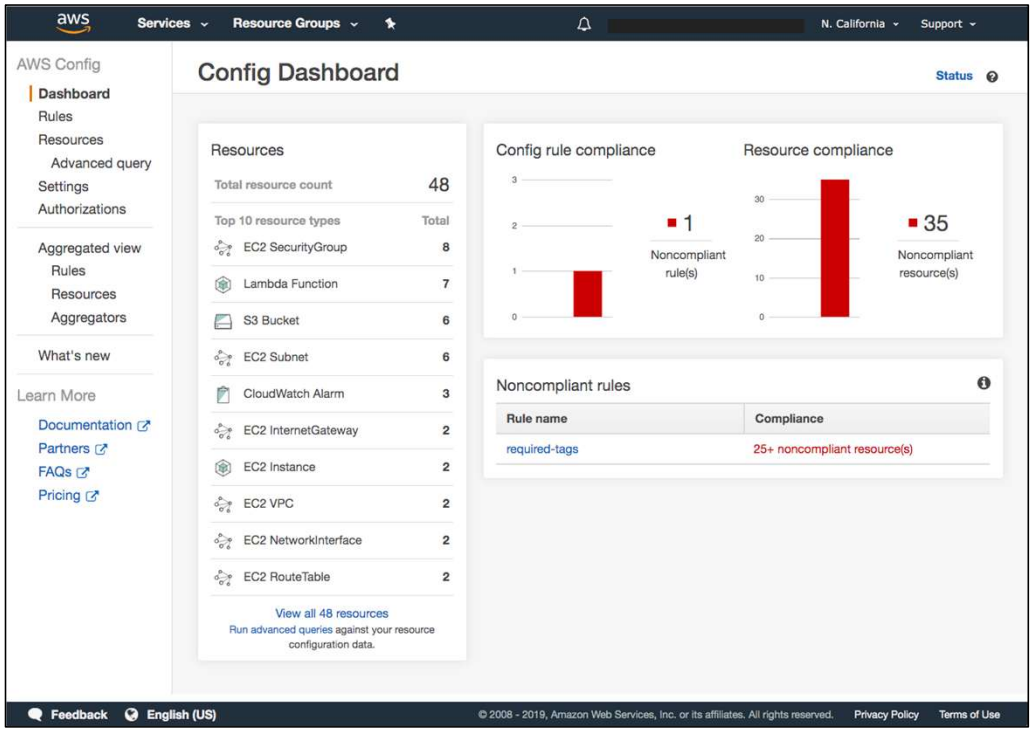
© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

AWS Config



AWS Config

Ejemplo de la vista del panel de AWS Config



- **Evalúe, audite y analice las configuraciones de sus recursos de AWS.**
- Utilícelo para el monitoreo continuo de las configuraciones.
- Evalúe automáticamente las configuraciones *registradas* frente a las configuraciones *deseadas.*
- Revise los cambios de configuración.
- Consulte historiales de configuración detallados.
- **Simplifique la auditoría de conformidad y el análisis de seguridad.**

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

AWS Artifact



AWS Artifact

- **Es un recurso destinado a la información relacionada con la conformidad.**
- Proporciona acceso a informes de seguridad y conformidad, así como también a acuerdos en línea seleccionados.
- Puede obtener acceso a descargas de ejemplo:
  - Certificaciones ISO de AWS
  - Informes del sector de tarjetas de pago (PCI) y del control de organizaciones de servicios (SOC)
- Puede acceder a AWS Artifact directamente desde la consola de administración de AWS
  - En **Security, Identify & Compliance** (Seguridad, identidad y conformidad), haga clic en **Artifact**.

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Aprendizajes clave de la sección 6



- Los **programas de conformidad de seguridad de AWS** proporcionan información acerca de las políticas, los procesos y los controles que establece y opera AWS.
- **AWS Config** se utiliza para analizar, auditar y evaluar las configuraciones de los recursos de AWS.
- **AWS Artifact** proporciona acceso a informes de seguridad y conformidad.

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Sección 7: Servicios y recursos de seguridad adicionales

Módulo 4: Seguridad en la nube de AWS



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

AWS Service Catalog



AWS Service Catalog

- **Cree y administre catálogos de servicios de TI aprobados por su organización.**
  - Ayuda a los empleados a encontrar e implementar servicios de TI *aprobados*.
  - Un servicio de TI puede incluir uno o varios recursos de AWS.
  - Ejemplo:
    - Instancias EC2, volúmenes de almacenamiento, bases de datos y componentes de red
- Controle el uso de los servicios de AWS a través de la especificación de restricciones:
  - Restricciones de ejemplo:
    - La región de AWS en la cual se puede lanzar un producto
    - Rangos de direcciones IP permitidos
- Administre de forma centralizada el ciclo de vida de los servicios de TI.
- Ayude a cumplir los requisitos de conformidad.

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Servicios de seguridad adicionales seleccionados



Amazon Macie

Proteja información de identificación personal (PII) de forma proactiva y entérese cuando se modifique su ubicación.



Amazon Inspector

Defina estándares y prácticas recomendadas para sus aplicaciones y **valide su conformidad** con estos **estándares**.



Amazon GuardDuty

Brinda **detección de amenazas** inteligente y monitoreo continuo para proteger sus cargas de trabajo y cuentas de AWS.

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Conclusión del módulo

Módulo 4: Seguridad en la nube de AWS



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Resumen del módulo

En resumen, en este módulo, aprendió a hacer lo siguiente:

- Reconocer el modelo de responsabilidad compartida
- Identificar la responsabilidad del cliente y de AWS
- Reconocer usuarios, grupos y roles de IAM
- Describir los diferentes tipos de credenciales de seguridad en IAM
- Identificar los pasos para proteger una nueva cuenta de AWS
- Explorar los usuarios y los grupos de IAM
- Reconocer cómo proteger los datos de AWS
- Reconocer los programas de conformidad de AWS

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Complete la revisión de conocimientos



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Pregunta de examen de ejemplo

¿Cuál de las siguientes opciones es responsabilidad de AWS en virtud del Modelo del responsabilidad compartida de AWS?

Opción	Respuesta
A	Configuración de aplicaciones de terceros
B	Mantenimiento del hardware físico
C	Protección del acceso a la aplicación y de los datos
D	Administración de las imágenes de máquina de Amazon (AMI) personalizadas.

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Respuesta a la pregunta de examen de ejemplo

¿Cuál de las siguientes opciones es responsabilidad de AWS en virtud del Modelo del responsabilidad compartida de AWS?

La respuesta correcta es la B.

Las palabras clave de la pregunta son “responsabilidad de AWS” y “modelo de responsabilidad compartida de AWS”.

© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Recursos adicionales

- Página de inicio de Seguridad en la nube de AWS: https://aws.amazon.com/security/
- Recursos de seguridad de AWS: https://aws.amazon.com/security/security-learning/?cards-top.sort-by=item.additionalFields.sortDate&cards-top.sort-order=desc&awsf.Types=*all
- Blog de seguridad de AWS: https://aws.amazon.com/blogs/security/
- Boletines de seguridad: https://aws.amazon.com/security/security-bulletins/?card-body.sort-by=item.additionalFields.bulletinId&card-body.sort-order=desc&awsf.bulletins-flag=*all&awsf.bulletins-year=*all
- Pruebas de intrusión y vulnerabilidad: https://aws.amazon.com/security/penetration-testing/
- Marco de Buena Arquitectura de AWS: pilar de seguridad: https://d1.awsstatic.com/whitepapers/architecture/AWS-Security-Pillar.pdf
- Documentación de AWS: prácticas recomendadas de IAM: https://docs.aws.amazon.com/IAM/latest/UserGuide/best-practices.html

© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.

Gracias

Todas las marcas comerciales pertenecen a sus propietarios.



© 2022 Amazon Web Services, Inc. o sus empresas afiliadas. Todos los derechos reservados.